RÉPUBLIQUE DU CAMEROUN

Université de Garoua

Faculté des Sciences · Département de Mathématiques et Informatiques

Master Professionnel en Sécurité des Systèmes Informatiques et des Données

Supervision, Analyse Forensique et Gestion des Incidents

Détecter, investiguer, maîtriser :
du SOC à la preuve opposable

SAFI - UE SIS589



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | Université de Garoua

Faculté des Sciences · Département de Mathématiques et Informatiques

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE SIS589

AVANT-PROPOS

Ce livre est le support de l'unité d'enseignement **SIS589, Supervision, Analyse Forensique et Gestion des Incidents**, du Master Professionnel en Sécurité des Systèmes Informatiques et des Données de l'Université de Garoua (Faculté des Sciences, Département de Mathématiques et Informatiques).

Il prolonge, sur le terrain opérationnel, les enseignements de sécurité et d'audit : là où l'on apprend ailleurs à apprécier les risques et à simuler les attaques, SIS589 apprend à **détecter, investiguer et maîtriser** ce qui survient en temps réel. Le fil conducteur est unique : une entreprise fictive, **LiZbiZ**, société de logistique présente à Garoua, subit un rançongiciel. Le cours suit l'incident sur trois temps (la supervision qui aurait dû le voir venir, l'analyse forensique qui l'établit, la réponse qui le maîtrise), à travers trois opérations situées dans le Nord : **BÉNOUÉ**, **FARO** et **MAYO**.

Chaque notion est ancrée à la fois dans les standards internationaux (ISO/IEC 27035 et 27037, NIST SP 800-86, RFC 3227, MITRE ATT&CK) et dans le droit camerounais et africain (lois n° 2010/012, 2010/013 et 2024/017, Convention de Malabo, Convention de Budapest). Un fil théorique parcourt le livre : le **Trilemme CRO** (Confidentialité, Fiabilité, Opposabilité), par lequel se juge toute trace et tout acte d'enquête.

Les cas sont fictifs : les noms, les dates et les montants le sont ; les mécanismes techniques et les références normatives sont exacts. Le livre s'accompagne de l'environnement **NDAP SUKULU**, qui fait pratiquer chaque chapitre.

MINKA MI NGUIDJOÏ Thierry Emmanuel

© *MaletYon*

MODE D'EMPLOI

À qui s'adresse ce cours

Aux étudiants du Master Professionnel en Sécurité des Systèmes Informatiques et des Données, et aux professionnels qui exercent ou se destinent aux métiers d'**analyste SOC**, d'**analyste forensique**, de **responsable de la réponse à incident** et de **RSSI**. Des notions de réseaux (TCP/IP), d'administration Windows et Linux et de droit numérique sont utiles.

Comment lire ce livre

Le livre comprend un prologue et six parties. Chaque chapitre suit le même plan : une épigraphe, le niveau et les prérequis, les objectifs, une question directrice, cinq à neuf sections, un encadré « à retenir », dix exercices gradués et une transition. Les niveaux des exercices sont signalés par des étoiles : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert.

Les encadrés

- **Scénario opérationnel** : un épisode des opérations BÉNOUÉ, FARO ou MAYO, avec *constatation* (faits) et *analyse* (interprétation, niveau de confiance).
- **Artefact** : la fiche d'une pièce d'enquête (nature, source, pertinence, fiabilité, opposabilité).
- **Chaîne de custody** : une procédure de préservation de la preuve.
- **Analyse CRO** : l'arbitrage Confidentialité, Fiabilité, Opposabilité.
- **Application métier** : ce que le chapitre change pour un métier.
- **Cadre juridique** : le texte de droit applicable.

Constatation et analyse

Le cours distingue systématiquement ce que l'on **constate** (un fait vérifiable) de ce que l'on en **déduit** (une interprétation, assortie d'un niveau de confiance). C'est la discipline première de la supervision et du forensique.

NDAP SUKULU et évaluation

L'environnement compagnon NDAP SUKULU (page suivante) propose, pour chaque chapitre, une fiche d'auto-évaluation et, pour les chapitres pratiques, un lab sur pièces. Fiches et labs se font hors des 30 heures de cours. Le code du cours est **SIS589**.

© *MaletYon*

NDAP SUKULU, L'ENVIRONNEMENT COMPAGNON



Ndap sukulu signifie « la salle de classe » en bassa, et *Malet Yon*, « ton enseignant ». **NDAP SUKULU** est l'environnement compagnon du cours : pour chaque chapitre, une fiche d'auto-évaluation de 40 questions, corrigée automatiquement ; pour les chapitres pratiques, un lab sur pièces (journaux, images, flux exportés) dans un cadre entièrement fermé ; et un tableau de bord de progression.

On y accède par le code de cours **SIS589**. Les fiches et les labs se font hors des 30 heures de cours. Les pièces des labs sont fictives et établies pour l'enseignement.

Les dix labs de NDAP SUKULU

Lab	Sujet	Ch.
SAFI-LAB-01	Lire un tableau de bord de supervision	3
SAFI-LAB-02	Analyser des journaux et repérer les angles morts	4
SAFI-LAB-03	Écrire et éprouver une règle de détection (SIEM)	7
SAFI-LAB-04	Reconnaître une intrusion dans des alertes corrélées	5
SAFI-LAB-05	Chaîne de custody et qualification d'artefacts	11
SAFI-LAB-06	Forensique système : reconstituer une chronologie	12
SAFI-LAB-07	Forensique réseau : exfiltration et pilotage (flux exportés)	14
SAFI-LAB-08	Classer et traiter des incidents (gravité, délais)	15
SAFI-LAB-09	Mapping d'un incident à MITRE ATT&CK	17
SAFI-LAB-10	Couverture de détection et verdict OUI/NON/NEK	20

Chaque lab dure environ une heure et se corrige automatiquement. Les pièces se trouvent dans le dossier `preuves` (lecture seule) et une copie de travail dans `travail`.

© *MaletYon*

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi v

NDAP SUKULU, l'environnement compagnon vii

Prologue Opérationnel 3

0 Prologue : la Découverte 3

0.1 Trois métiers, une seule journée . . . 4
0.2 Le fil rouge : LiZbiZ et ses opérations . . . 4
0.3 Le Trilemme CRO . . . 5
0.4 Les questions du cours . . . 5

I Superviser : le Centre d'Opérations de Sécurité 7

1 Pourquoi Superviser 9

1.1 Prévenir ne Suffit Pas . . . 10
1.2 Qu'est-ce que Superviser . . . 10
1.3 Le Délai de Présence . . . 10
1.4 Superviser, une Obligation . . . 10
1.5 Les Indicateurs Fondamentaux . . . 11

2 L'Architecture d'un SOC 13

2.1 La Mission du SOC . . . 14
2.2 Les Niveaux d'Analyse . . . 14
2.3 Les Modèles d'Organisation . . . 14
2.4 Les Fonctions Transverses . . . 14
2.5 Dimensionner pour une PME . . . 15

3 Gouvernance et Indicateurs de la Supervision 17

3.1 Gouverner la Supervision . . . 18
3.2 Trois Familles d'Indicateurs . . . 18
3.3 Le Tableau de Bord . . . 18
3.4 Les Objectifs de Délai . . . 18
3.5 Rendre Compte . . . 19

© *MaletYon*

II Collecter et Détecter 21

4 Les Journaux 23

4.1 Les Sources de Journaux . . . 24
4.2 Normaliser et Horodater . . . 24
4.3 Collecter et Conserver . . . 24
4.4 L'Obligation de Conservation . . . 25
4.5 Les Angles Morts . . . 25

5 Le SIEM 29

5.1 Qu'est-ce qu'un SIEM . . . 30
5.2 La Chaîne de Traitement . . . 30
5.3 Les Cas d'Usage . . . 30
5.4 Corréler, pas seulement Chercher . . . 30
5.5 Les Pièges . . . 31

6 La Détection d'Intrusion (IDS/IPS) 35

6.1 IDS et IPS, Réseau et Hôte . . . 36
6.2 Signatures ou Anomalies . . . 36
6.3 Le Placement des Sondes . . . 36
6.4 Détecter ou Bloquer . . . 36

7 Écrire et Éprouver une Règle de Détection 39

7.1 Énoncer avant de Coder . . . 40
7.2 Relier à une Technique et à sa Trace . . . 40
7.3 Éprouver une Règle . . . 40
7.4 Maintenir le Catalogue . . . 41

III Cadre Normatif et Juridique 43

8 Normes de la Gestion d'Incident et de la Preuve 45

8.1 Le Cycle ISO/IEC 27035 . . . 46
8.2 La Preuve selon l'ISO/IEC 27037 . . . 46
8.3 NIST SP 800-86 et RFC 3227 . . . 46
8.4 Articuler les Référentiels . . . 47

9 Le Cadre Juridique 49

9.1 La Loi 2010/012 et la Loi 2010/013 . . . 50
9.2 Les Données Personnelles . . . 50
9.3 L'ANTIC . . . 50
9.4 Malabo et Budapest . . . 50
9.5 Les Obligations de LiZbiZ . . . 51

10 L'Admissibilité de la Preuve Numérique **53**

10.1 Qu'est-ce que l'Admissibilité . . . 54
10.2 Intégrité, Authenticité, Traçabilité . . . 54
10.3 Le Trilemme CRO Appliqué . . . 54
10.4 Ce qui Détruit une Preuve . . . 54

IV L'Analyse Forensique **57**

11 Fondements du Forensique et Chaîne de Custody **59**

11.1 Qu'est-ce que le Forensique . . . 60
11.2 L'Ordre de Volatilité . . . 60
11.3 La Copie Vérifiée . . . 60
11.4 La Chaîne de Custody . . . 60
11.5 Qualifier un Artefact . . . 61

12 Forensique Système **63**

12.1 Les Artefacts Windows . . . 64
12.2 Les Artefacts Linux . . . 64
12.3 La Chronologie . . . 64
12.4 Suppression et Récupération . . . 65

13 Forensique Mémoire **69**

13.1 Pourquoi la Mémoire . . . 70
13.2 Ce qu'elle Révèle . . . 70
13.3 L'Acquisition . . . 70
13.4 Le Coût du Redémarrage . . . 71

14 Forensique Réseau **73**

14.1 Les Sources de Traces Réseau . . . 74
14.2 Exfiltration et Pilotage . . . 74
14.3 Lire des Flux Exportés . . . 74
14.4 Recouper avec le Système . . . 75

V La Réponse à Incident **79**

15 Le Cycle de Réponse à Incident **81**

15.1 Le Cycle . . . 82
15.2 Classer par Gravité . . . 82
15.3 La Préparation . . . 82
15.4 Réponse et Forensique . . . 83

16 Le CSIRT et le CERT **85**

16.1 CSIRT et CERT . . . 86
16.2 Les Rôles de la Cellule . . . 86
16.3 La Main Courante . . . 86
16.4 Coopérer avec l'Extérieur . . . 87

17 Le Renseignement sur la Menace **89**

17.1 Qu'est-ce que le Renseignement . . . 90
17.2 Chaîne d'Attaque et ATT&CK . . . 90
17.3 Le Modèle du Diamant . . . 90
17.4 Échanger le Renseignement . . . 90

18 Confinement, Éradication, Rétablissement **95**

18.1 Le Confinement . . . 96
18.2 L'Éradication . . . 96
18.3 Le Rétablissement . . . 96
18.4 Faut-il Payer ? . . . 97

VI Apprendre et Mesurer **99**

19 Retour d'Expérience et Amélioration Continue **101**

19.1 Conduire un RETEX . . . 102
19.2 Causes Immédiates et Profondes . . . 102
19.3 Des Leçons aux Actions . . . 102
19.4 La Culture Juste . . . 103

20 Mesurer la Supervision et la Réponse **105**

20.1 Des Indicateurs Honnêtes . . . 106
20.2 Le Verdict à Trois Valeurs . . . 106
20.3 Les Indicateurs Trompeurs . . . 107
20.4 Le Cycle et la Recherche . . . 107

A Glossaire **111**

B Référentiel des Outils **113**

C Modèles et Procédures **115**

D Textes Juridiques et Normatifs **117**

E Bibliographie Commentée **119**

F Contacts et Ressources **121**

Références bibliographiques **123**

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : LA DÉCOUVERTE

« Quand l'écran de rançon s'affiche, l'attaque est déjà vieille ;
la seule question est de savoir si quelqu'un l'a vue venir. »

Principe du cours

Niveau : *Introductif* • Aucun prérequis. Les notions sont reprises en détail dans les chapitres.

✦ Objectifs du chapitre

- ➢ Situer la supervision, le forensique et la réponse à incident dans une même journée réelle.
- ➢ Distinguer ce qui relève de la détection, de l'investigation et de la décision.
- ➢ Découvrir le fil rouge LiZbiZ et le Trilemme CRO.
- ➢ Formuler les questions auxquelles le cours répond.

6 mars 2026, 6 h 40, site de LiZbiZ à Garoua

Le vigile de nuit a cru à une coupure : les écrans de l'entrepôt affichent tous le même fond noir et un texte en anglais réclamant un paiement. À 6 h 40, l'astreinte informatique est jointe. À 7 h 15, M. KOUNOU, responsable informatique, constate que le serveur de fichiers `FS-01`, la base de suivi des colis et deux postes de la comptabilité sont chiffrés. Les sauvegardes de la semaine sont, elles aussi, inaccessibles.

Ce que personne ne sait encore ce matin-là[1] : l'attaque n'a pas commencé cette nuit. Les premières traces, dans les journaux, remontent à onze jours plus tôt. La première reconstitution, faite dans la semaine de l'attaque, partait de la connexion du 2 mars à la passerelle d'accès distant. L'analyse forensique a trouvé ensuite des traces dès le 24 février. Entre les deux, un compte de service compromis, un déplacement discret d'une machine à l'autre, une exfiltration de 40 Go, puis le chiffrement. Pendant onze jours, tout était dans les journaux. Personne ne les lisait.

[1] Cas fictif établi pour le cours. Les noms (LiZbiZ, NYONG SÉCURITÉ, BANQUE SANAGA), les dates et les montants sont fictifs ; les mécanismes techniques et les références normatives sont exacts.

© MaletYon

0.1 Trois métiers, une seule journée

Cette journée met en scène les trois compétences du cours, dans l'ordre où elles interviennent.

Moment	Compétence	Question posée
Avant (onze jours)	Supervision, détection	L'a-t-on vu venir ?
Pendant (le constat)	Réponse à incident	Comment limiter les dégâts ?
Après (l'enquête)	Analyse forensique	Que s'est-il exactement passé, et peut-on le prouver ?

Tableau 0.1. Les trois temps d'un incident

Scénario Opérationnel · Opération GAROUA. La journée du 6 mars

Constatation. À 7 h 15, quatre systèmes chiffrés, sauvegardes hebdomadaires inaccessibles, un message de rançon. La production de l'entrepôt de Garoua est arrêtée.

Analyse (confiance moyenne au matin, élevée après enquête). L'incident n'est pas un simple chiffrement : c'est l'aboutissement d'une intrusion de onze jours. La distinction entre ce que l'on *constate* (les écrans noirs) et ce que l'on *suppose* puis *établit* (le chemin de l'attaquant) est le cœur du métier.

0.2 Le fil rouge : LiZbiZ et ses opérations

Tout le cours suit la même entreprise, LiZbiZ, société de logistique présent à Yaoundé, Douala et Garoua, et le cabinet NYONG SÉCURITÉ qui l'assiste. Trois opérations, situées dans le Nord, structurent la pratique :

Opération	Ce qu'elle illustre
BÉNOUÉ	La supervision et la détection : ce que le SIEM a vu, et pas vu, pendant les onze jours
FARO	L'analyse forensique : disque, mémoire, réseau, et la preuve opposable
MAYO	La réponse à incident : confinement, éradication, rétablissement, retour d'expérience

Tableau 0.2. Les trois opérations du fil rouge

Acteur	Rôle
M. KOUNOU	Responsable informatique de LiZbiZ
Mme DJUIDJE	Analyste SOC, cabinet NYONG SÉCURITÉ
M. BIKORO	Analyste forensique et chef de mission
Mme NGASSA	Responsable de la réponse à incident
M. ETEME	Directeur général de LiZbiZ

Tableau 0.3. Les acteurs de l'opération GAROUA

0.3 Le Trilemme CRO

Ce cours partage avec l'investigation numérique un fil conducteur théorique : toute trace, tout acte d'enquête se juge sur trois dimensions à la fois.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Le Trilemme CRO. **Confidentialité** : la trace et l'enquête ne doivent pas exposer plus de données que nécessaire. **Fiabilité** : la trace est-elle fidèle, complète, non altérée ? **Opposabilité** : pourra-t-on s'en prévaloir devant un tiers (direction, ANTIC, juge) ?

Une action d'enquête améliore souvent une dimension au détriment d'une autre. On la note $\mathcal{C}$: + $\mathcal{F}$: - $\mathcal{O}$: 0 : ici, confidentialité préservée, fiabilité dégradée, opposabilité inchangée. Le professionnel arbitre en conscience et *documente* son arbitrage.

0.4 Les questions du cours

Note

Ce que le cours apprend à répondre.

- Comment **superviser** un système pour voir l'attaque pendant qu'elle se déroule (Parties I et II) ?
- Que disent les **normes et le droit** sur la preuve et le signalement (Partie III) ?
- Comment **investiguer** proprement disque, mémoire et réseau (Partie IV) ?
- Comment **répondre** à l'incident et s'en relever (Partie V) ?
- Comment **apprendre** et mesurer, pour que la prochaine fois quelqu'un voie venir l'attaque (Partie VI) ?

★ À retenir

Ce qu'il faut retenir de ce prologue :

- ➢ **L'écran de rançon** est la fin d'une histoire, pas le début.
- ➢ **Trois temps** : voir venir (supervision), limiter (réponse), établir (forensique).
- ➢ **Le fil rouge** LiZbiZ et les opérations BÉNOUÉ, FARO, MAYO.
- ➢ **Le Trilemme CRO** : confidentialité, fiabilité, opposabilité.
- ➢ **Constater** n'est pas **supposer** ; on sépare toujours les deux.

● Note

Transition. Pour voir venir l'attaque, il faut d'abord comprendre pourquoi et comment on supervise : c'est l'objet du Chapitre 1.

partie I

Superviser : le Centre d'Opérations de Sécurité

© MaletYon

1

POURQUOI SUPERVISER

« On ne défend pas ce que l'on ne voit pas. »

Principe du cours

Niveau : *Fondamental* • Le prologue ; notions de réseaux et de systèmes.

✦ Objectifs du chapitre

- ➢ Définir la supervision de sécurité et la distinguer de la supervision d'exploitation.
- ➢ Situer la détection dans la chaîne prévention, détection, réaction.
- ➢ Comprendre le délai de présence de l'attaquant et pourquoi il compte.
- ➢ Relier la supervision aux obligations de l'entreprise.
- ➢ Poser les indicateurs fondamentaux de la détection.

Question directrice : si tout était dans les journaux, pourquoi personne n'a-t-il rien vu ?

Onze jours de présence, des traces à chaque étape, et pourtant la découverte par un écran de rançon. Ce chapitre explique pourquoi la prévention ne suffit pas, ce qu'est superviser, et comment se mesure la capacité à voir venir.

Plan du chapitre.

1. Prévenir ne suffit pas (section 1.1).
2. Qu'est-ce que superviser (section 1.2).
3. Le délai de présence (section 1.3).
4. Superviser, une obligation (section 1.4).
5. Les indicateurs fondamentaux (section 1.5).

© *MaletYon*

1.1 Prévenir ne Suffit Pas

La sécurité se joue sur trois temps : **prévention** (empêcher), **détection** (voir ce qui est passé malgré la prévention) et **réaction** (limiter et corriger). Aucune prévention n'est parfaite : un correctif manquant, un mot de passe faible, un courriel piégé suffisent. La détection est le filet qui rattrape ce que la prévention a laissé passer.

1.2 Qu'est-ce que Superviser

Définition

Supervision de sécurité : collecte continue des traces d'un système, leur corrélation et leur analyse pour détecter, le plus tôt possible, les activités malveillantes ou anormales. Elle se distingue de la **supervision d'exploitation**, qui surveille la disponibilité et la performance, non les attaques.

1.3 Le Délai de Présence

Définition

Délai de présence (temps de séjour) : durée entre la première compromission et sa détection. Plus il est long, plus l'attaquant s'étend, exfiltre et s'installe.

Scénario Opérationnel · Opération BÉNOUÉ. Onze jours

Constatation. Première trace le 23 février (connexion d'un compte de service à une heure inhabituelle) ; chiffrement dans la nuit du 5 au 6 mars. Délai de présence : onze jours.

Analyse (confiance élevée). Réduire ce délai de onze jours à quelques heures aurait permis de contenir l'attaque avant l'exfiltration et le chiffrement. C'est l'objectif premier de la supervision.

1.4 Superviser, une Obligation

Jurisprudence & Droit applicable

Au Cameroun, la loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité impose la conservation des traces de connexion et la coopération avec l'ANTIC en cas d'incident (Chapitre 9). Ne pas disposer de journaux exploitables n'est pas seulement une faiblesse technique : c'est un manquement opposable.

1.5 Les Indicateurs Fondamentaux

Indicateur	Ce qu'il mesure
Délai moyen de détection	Temps entre compromission et alerte
Délai moyen de réaction	Temps entre alerte et confinement
Couverture de journalisation	Part des systèmes dont les traces sont collectées
Taux de faux positifs	Alertes sans incident réel
Taux de détection	Part des attaques (ou techniques) effectivement vues

Tableau 1.1. Indicateurs fondamentaux de la supervision

Application Analyste SOC

Mesurer pour progresser. L'analyste ne se contente pas de traiter les alertes : il suit le délai de détection d'un mois sur l'autre et l'améliore. Un SOC qui ne mesure pas son délai de détection ne sait pas s'il s'améliore.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Prévention, détection, réaction** : la détection rattrape ce que la prévention laisse passer.
- **Superviser** la sécurité n'est pas superviser l'exploitation.
- **Le délai de présence** est l'ennemi ; le réduire est l'objectif.
- **Superviser est une obligation** (loi 2010/012).
- **On mesure** délai de détection, de réaction, couverture.

Note

Points de contrôle de l'élève. Je sais : définir la supervision de sécurité ; situer la détection dans la chaîne ; expliquer le délai de présence ; rappeler l'obligation légale ; citer les indicateurs.

Exercice 1.1. Trois temps ★☆☆

Classez : installer un correctif ; lire les journaux chaque matin ; isoler un poste infecté. À quel temps (prévention, détection, réaction) chacun appartient-il ?

✍ Exercice 1.2. Deux supervisions ★☆☆

Distinguez supervision de sécurité et supervision d'exploitation par un exemple de chacune.

✍ Exercice 1.3. Le délai ★☆☆

Calculez le délai de présence de l'opération BÉNOUÉ. Pourquoi le réduire ?

✍ Exercice 1.4. Le filet ★★☆

« Puisque nous avons un pare-feu et un antivirus, la détection est inutile. » Répondez.

✍ Exercice 1.5. Obligation ★★☆

En quoi l'absence de journaux exploitables est-elle un manquement opposable chez LiZbiZ ?

✍ Exercice 1.6. Indicateurs ★★☆

Pour LiZbiZ, proposez une valeur cible de délai de détection et justifiez-la.

✍ Exercice 1.7. Couverture ★★☆

Pourquoi une couverture de journalisation partielle crée-t-elle des angles morts ?

✍ Exercice 1.8. Faux positifs ★★☆

Quel risque un taux de faux positifs trop élevé fait-il courir à la détection ?

✍ Exercice 1.9. Tableau de bord ★★★

Construisez le tableau de bord de supervision que LiZbiZ devrait suivre après l'opération GAROUA.

✍ Exercice 1.10. Note à la direction ★★★

Rédigez une note qui explique à M. ETEME pourquoi investir dans la détection, et non seulement dans la prévention.

Note

Pour aller plus loin.

➢ ISO/IEC 27035 [11] ; NIST SP 800-61r2 [4].

Note

Transition. Superviser suppose une organisation : le Chapitre 2 présente l'architecture d'un centre d'opérations de sécurité.

2

L'ARCHITECTURE D'UN SOC

« Un SOC n'est pas une salle pleine d'écrans ;
c'est un processus qui transforme des traces en décisions. »

Principe du cours

Niveau : *Fondamental* • Chapitre 1.

✦ Objectifs du chapitre

- ➢ Définir le centre d'opérations de sécurité (SOC) et sa mission.
- ➢ Décrire les niveaux d'analyse (N1, N2, N3) et leurs rôles.
- ➢ Comprendre les modèles d'organisation (interne, infogéré, hybride).
- ➢ Situer les fonctions chasse, ingénierie de détection, réponse.
- ➢ Dimensionner un SOC réaliste pour une PME.

Question directrice : de quelle équipe LiZbiZ a-t-elle besoin pour voir venir la prochaine attaque ?

LiZbiZ n'a ni SOC ni analyste dédié ; M. KOUNOU fait tout. Ce chapitre montre ce qu'est un SOC, ses rôles et ses modèles, et comment en bâtir un proportionné à une PME, seul ou avec le cabinet NYONG SÉCURITÉ.

Plan du chapitre.

1. La mission du SOC (section 2.1).
2. Les niveaux d'analyse (section 2.2).
3. Les modèles d'organisation (section 2.3).
4. Les fonctions transverses (section 2.4).
5. Dimensionner pour une PME (section 2.5).

© MaletYon

2.1 La Mission du SOC

Définition

SOC (*Security Operations Center*) : fonction, humaine et technique, chargée de détecter, analyser et traiter les événements de sécurité en continu, à partir des traces collectées par le SIEM et les sondes.

2.2 Les Niveaux d'Analyse

Niveau	Rôle	Ce qu'il fait
N1	Surveillance, tri	Reçoit les alertes, écarte les faux positifs, qualifie, escalade
N2	Investigation	Analyse l'alerte qualifiée, reconstitue, décide du traitement
N3	Expertise, chasse	Forensique, chasse proactive, ingénierie de détection

Tableau 2.1. Les niveaux d'un SOC

Attention

Erreur fréquente. Vouloir trois niveaux dès le premier jour.

Règle : une PME commence souvent par un N1 outillé et un N2 à temps partiel, l'expertise N3 étant externalisée. L'organisation suit la maturité, pas l'inverse.

2.3 Les Modèles d'Organisation

Modèle	Principe	Pour qui
Interne	Équipe propre, 24/7 ou heures ouvrées	Grandes organisations
Infogéré (MSSP)	Un prestataire opère le SOC	PME sans équipe
Hybride	N1/N2 infogéré, N3 et décision internes	Cas fréquent et équilibré

Tableau 2.2. Modèles d'organisation d'un SOC

2.4 Les Fonctions Transverses

Au-delà des niveaux, un SOC mûr distingue trois fonctions : la **chasse** (rechercher activement ce qui n'a pas déclenché d'alerte, Chapitre 17), l'**ingénierie de détection** (écrire et maintenir les règles, Chapitre 7) et la **réponse** (traiter l'incident, Partie V). Elles se nourrissent l'une l'autre : chaque incident traité améliore les règles.

2.5 Dimensionner pour une PME

Scénario Opérationnel · Opération BÉNOUÉ. Le SOC qui n'existait pas

Constatation. LiZbiZ n'avait aucune fonction de détection : pas de SIEM, pas d'analyste, des journaux dispersés et non lus.

Analyse (confiance élevée). Un modèle hybride convient : le cabinet NYONG SÉCURITÉ opère la surveillance (N1/N2) sur un SIEM mutualisé, LiZbiZ garde la décision et le lien avec l'ANTIC. Le coût est compatible avec une PME, et le délai de présence tombe de onze jours à quelques heures.

Application RSSI

Choisir un modèle soutenable. Le RSSI ne vise pas le SOC le plus complet, mais celui que l'organisation peut financer et faire vivre dans la durée. Un SOC interne sous-doté détecte moins bien qu'un infogéré bien piloté.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le SOC** transforme des traces en décisions, en continu.
- **N1, N2, N3** : tri, investigation, expertise.
- **Interne, infogéré, hybride** : le modèle suit la maturité et le budget.
- **Chasse, ingénierie de détection, réponse** : les fonctions transverses.
- **Pour une PME**, l'hybride est souvent le bon départ.

Note

Points de contrôle de l'élève. Je sais : définir un SOC ; décrire N1/N2/N3 ; comparer les modèles ; situer chasse, ingénierie, réponse ; proposer un SOC pour une PME.

Exercice 2.1. Les niveaux ★☆☆

Associez à N1, N2 ou N3 : écarter un faux positif ; faire du forensique ; décider d'isoler un serveur.

Exercice 2.2. SOC ou exploitation ★☆☆

Pourquoi un SOC n'est-il pas « une salle pleine d'écrans » ?

✍ Exercice 2.3. Modèles ★☆☆

Citez un avantage et une limite de chaque modèle (interne, infogéré, hybride).

✍ Exercice 2.4. Maturité ★★☆

Pourquoi déconseille-t-on à une PME de monter d'emblée trois niveaux internes ?

✍ Exercice 2.5. Hybride ★★☆

Dans le modèle hybride de LiZbiZ, qui garde la décision ? Pourquoi ?

✍ Exercice 2.6. Fonctions ★★☆

Expliquez comment un incident traité améliore les règles de détection.

✍ Exercice 2.7. Escalade ★★☆

Décrivez le parcours d'une alerte de N1 à N2, avec les critères d'escalade.

✍ Exercice 2.8. Chasse ★★☆

En quoi la chasse diffère-t-elle du traitement d'alerte ?

✍ Exercice 2.9. Proposition ★★★

Rédigez une proposition de SOC hybride pour LiZbiZ : périmètre, rôles, horaires, responsabilités partagées avec NYONG SÉCURITÉ.

✍ Exercice 2.10. Convention de service ★★★

Quels engagements de service (délais, couverture, rapports) inscririez-vous au contrat avec un SOC infogéré ?

● Note

Pour aller plus loin.

➢ NIST SP 800-61r2 [4] ; CIS Controls v8 [3].

● Note

Transition. Un SOC se pilote : le Chapitre 3 traite de sa gouvernance et de ses indicateurs.

3

GOUVERNANCE ET INDICATEURS DE LA SUPERVISION

« Ce qui ne se mesure pas ne se pilote pas ;
ce qui ne se pilote pas se dégrade. »

Principe du cours

Niveau : *Fondamental* • Chapitres 1 et 2.

✦ Objectifs du chapitre

- ➢ Définir la gouvernance d'un dispositif de supervision.
- ➢ Distinguer indicateurs d'activité, de performance et de résultat.
- ➢ Construire un tableau de bord utile et honnête.
- ➢ Fixer des objectifs de délai (détection, réaction).
- ➢ Rendre compte à la direction sans noyer sous la technique.

Question directrice : comment savoir si la supervision de LiZbiZ s'améliore vraiment ?

Après l'incident, LiZbiZ met en place une détection. Six mois plus tard, M. ETEME demande : « Sommes-nous mieux protégés ? » La réponse ne peut être ni « oui » vague ni une avalanche de courbes : elle tient dans quelques indicateurs choisis et suivis dans le temps.

Plan du chapitre.

1. Gouverner la supervision (section 3.1).
2. Trois familles d'indicateurs (section 3.2).
3. Le tableau de bord (section 3.3).
4. Les objectifs de délai (section 3.4).
5. Rendre compte (section 3.5).

© *MaletYon*

3.1 Gouverner la Supervision

Définition

Gouvernance de la supervision : ensemble des décisions qui fixent le périmètre surveillé, les priorités, les moyens, les responsabilités et les indicateurs, et qui en rendent compte à la direction. Elle relie la technique à la stratégie.

3.2 Trois Familles d'Indicateurs

Famille	Question	Exemple
Activité	Que fait-on ?	Nombre d'alertes traitées
Performance	Le fait-on bien et vite ?	Délai moyen de détection
Résultat	Est-on plus sûr ?	Part des techniques détectées, incidents évités

Tableau 3.1. Trois familles d'indicateurs [8]

Attention

Erreur fréquente. Ne suivre que l'activité (« nous avons traité 3 000 alertes »).

Règle : l'activité ne dit rien de l'efficacité. Un volume d'alertes élevé peut signaler de mauvaises règles, non une bonne détection. On privilégie la performance et le résultat.

3.3 Le Tableau de Bord

Chaîne de custody

Construire un tableau de bord de supervision

1. Choisir cinq à sept indicateurs, pas plus.
2. Au moins un de chaque famille (activité, performance, résultat).
3. Pour chacun : définition, source, cible, tendance.
4. Montrer l'évolution, pas seulement la valeur du mois.
5. Dire honnêtement ce qui n'est pas couvert.

3.4 Les Objectifs de Délai

Les deux délais cardinaux sont le **délai de détection** et le **délai de réaction**. On les fixe par type d'incident : un rançongiciel exige une détection en minutes et un confinement en moins d'une heure ; une anomalie mineure tolère un traitement en jours. Ces cibles guident le dimensionnement du SOC (Chapitre 2).

3.5 Rendre Compte

Scénario Opérationnel · Opération BÉNOUÉ. Six mois après

Constatation. Nouveau tableau de bord : délai de détection médian ramené à 2 heures, couverture de journalisation portée à 85 %, 40 % des techniques ATT&CK jouées en test désormais détectées.

Analyse (confiance moyenne). Les chiffres montrent un progrès réel, mais la couverture reste partielle (15 % des systèmes non journalisés) et la détection en direct limitée : ce sont les NEK à traiter (Chapitre 20). Rendre compte, c'est aussi dire cela.

Application RSSI et analyste SOC

Un tableau de bord par lecteur. Le RSSI présente à la direction trois indicateurs de résultat ; l'analyste suit en interne le détail de la performance. Les deux disent la même vérité, à deux niveaux.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Gouverner**, c'est relier la supervision à la stratégie.
- **Activité, performance, résultat** : trois familles.
- **L'activité seule** trompe ; on vise performance et résultat.
- **Cinq à sept indicateurs**, avec tendance et angles morts.
- **Des objectifs de délai** par type d'incident.

Note

Points de contrôle de l'élève. Je sais : définir la gouvernance de la supervision ; classer un indicateur ; bâtir un tableau de bord ; fixer des délais cibles ; rendre compte à deux niveaux.

Exercice 3.1. Familles ★☆☆

Classez : nombre d'alertes ; délai de détection ; part des techniques détectées.

Exercice 3.2. Activité trompeuse ★☆☆

Pourquoi « 3 000 alertes traitées » ne prouve-t-il pas une bonne détection ?

✍ Exercice 3.3. Combien ★☆☆

Combien d'indicateurs un tableau de bord devrait-il comporter, et pourquoi pas plus ?

✍ Exercice 3.4. Cibles ★★☆

Proposez des délais cibles de détection et de réaction pour un rançongiciel, et justifiez.

✍ Exercice 3.5. Lire BÉNOUÉ ★★☆

Commentez les chiffres de l'opération BÉNOUÉ à six mois : progrès et limites.

✍ Exercice 3.6. Angles morts ★★☆

Pourquoi faut-il afficher ce qui n'est pas couvert dans un tableau de bord ?

✍ Exercice 3.7. Deux lecteurs ★★☆

Quels indicateurs montrez-vous à la direction ? Lesquels gardez-vous en interne ?

✍ Exercice 3.8. Tendance ★★☆

Pourquoi la tendance importe-t-elle plus que la valeur d'un mois isolé ?

✍ Exercice 3.9. Tableau de bord ★★★

Construisez le tableau de bord complet de supervision de LiZbiZ : sept indicateurs, définition, source, cible.

✍ Exercice 3.10. Présentation au comité ★★★

Rédigez la page que le RSSI présente au comité de direction pour répondre à « Sommes-nous mieux protégés ? ».

Note

Pour aller plus loin.

➢ ISO/IEC 27004 [8] ; ISO/IEC 27035 [11].

Note

Transition. La supervision commence par les traces : la Partie II s'ouvre sur les journaux (Chapitre 4).

partie II

Collecter et Détecter

© *MaletYon*

4

LES JOURNAUX

« Un journal que l'on ne collecte pas est une mémoire que l'on efface. »

Principe du cours

Niveau : *Fondamental* • Chapitre 1 ; notions de systèmes et de réseaux.

✦ Objectifs du chapitre

- ➢ Identifier les sources de journaux utiles à la détection.
- ➢ Comprendre la normalisation et l'horodatage.
- ➢ Fixer une politique de collecte et de conservation.
- ➢ Relier la journalisation aux obligations légales.
- ➢ Repérer les angles morts d'une journalisation partielle.

Question directrice : parmi tous les journaux de LiZbiZ, lesquels auraient révélé l'intrusion ?

L'attaque a laissé des traces : une connexion anormale d'un compte de service, une création de compte, un service installé à distance. Encore fallait-il que ces journaux existent, soient collectés et conservés. Ce chapitre recense les sources, leur normalisation et leur conservation.

Plan du chapitre.

1. Les sources de journaux (section 4.1).
2. Normaliser et horodater (section 4.2).
3. Collecter et conserver (section 4.3).
4. L'obligation de conservation (section 4.4).
5. Les angles morts (section 4.5).

© *MaletYon*

4.1 Les Sources de Journaux

Source	Ce qu'elle révèle
Journaux du domaine (Windows)	Connexions, créations de comptes, services, tâches
Journaux système (Linux)	Authentifications, sudo, démons, cron
Pare-feu et mandataire	Connexions, flux refusés, destinations
Serveurs d'application	Accès, erreurs, requêtes
Messagerie	Courriels reçus, pièces jointes, signalements
Équipements (imprimantes, bornes)	Accès d'administration

Tableau 4.1. Sources de journaux utiles à la détection

4.2 Normaliser et Horodater

Des journaux hétérogènes ne se corrèlent que s'ils sont **normalisés** (ramenés à un format commun : qui, quoi, quand, où) et surtout **horodatés** de façon cohérente. Une source d'horloge commune (NTP) est indispensable : sans elle, impossible de reconstituer une chronologie, et la preuve perd sa fiabilité.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO de l'horodatage. Un horodatage fiable et synchronisé sert la $\mathcal{C}$: 0 $\mathcal{F}$: + $\mathcal{O}$: + : il ne change rien à la confidentialité, améliore la fiabilité de la trace et son opposabilité devant un tiers. Un horodatage incohérent ruine l'opposabilité d'une chronologie, même exacte.

4.3 Collecter et Conserver

Chaîne de custody

Politique de collecte des journaux

1. Lister les sources et leur criticité.
2. Centraliser les journaux hors des machines surveillées (un attaquant efface les journaux locaux).
3. Protéger l'intégrité (accès restreint, écriture seule, condensats).
4. Synchroniser les horloges (NTP).
5. Fixer une durée de conservation conforme au droit et aux besoins.

4.4 L'Obligation de Conservation

Jurisprudence & Droit applicable

La loi n° 2010/012 et la loi n° 2010/013 sur les communications électroniques imposent aux opérateurs et aux entreprises la conservation des données de connexion et leur mise à disposition des autorités. Les durées et modalités précises se lisent dans le texte publié ; le cours en retient le principe : des journaux fiables, conservés, sont une obligation autant qu'un outil.

4.5 Les Angles Morts

Scénario Opérationnel · Opération BÉNOUÉ. Ce qui n'était pas journalisé

Constatation. Les contrôleurs de domaine journalisaient les connexions, mais le serveur de fichiers `FS-01` n'envoyait rien au central, et l'horloge d'un poste de Garoua avançait de 40 minutes.

Analyse (confiance élevée). L'intrusion a laissé des traces visibles sur le domaine, mais l'exfiltration depuis `FS-01` est restée invisible faute de collecte, et l'écart d'horloge a brouillé la chronologie. Deux angles morts à combler en priorité.

Application Analyste SOC

Cartographier avant de corréler. L'analyste tient à jour la carte des sources journalisées et de leurs manques : une détection n'est fiable que sur un périmètre connu. Ce qui n'est pas collecté doit être dit, non ignoré.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Les sources** : domaine, système, pare-feu, applications, messagerie, équipements.
- **Normaliser et horodater** conditionnent la corrélation.
- **Centraliser et protéger** les journaux hors des machines surveillées.
- **Conserver** est une obligation légale.
- **Les angles morts** (sources non collectées, horloges dérivées) sont des priorités.

Note

Points de contrôle de l'élève. Je sais : citer les sources de journaux ; expliquer normalisation et horodatage ; rédiger une politique de collecte ; rappeler l'obligation ; repérer un angle mort.

✍ Exercice 4.1. Sources ★☆☆

Quelle source journalise la création d'un compte ? L'exfiltration depuis un partage de fichiers ?

✍ Exercice 4.2. Horloge ★☆☆

Pourquoi une horloge commune (NTP) est-elle indispensable ?

✍ Exercice 4.3. Centraliser ★☆☆

Pourquoi centraliser les journaux hors des machines surveillées ?

✍ Exercice 4.4. Normaliser ★★☆

Qu'apporte la normalisation à la corrélation de journaux hétérogènes ?

✍ Exercice 4.5. CRO ★★☆

Expliquez l'analyse CRO de l'horodatage de l'opération BÉNOUÉ.

✍ Exercice 4.6. Angle mort ★★☆

Pourquoi l'exfiltration depuis `FS-01` est-elle restée invisible ?

✍ Exercice 4.7. Conservation ★★☆

Quels critères fixent la durée de conservation des journaux ?

✍ Exercice 4.8. Intégrité ★★☆

Comment garantir qu'un attaquant ne puisse pas effacer les journaux centralisés ?

✍ Exercice 4.9. Politique ★★★

Rédigez la politique de journalisation de LiZbiZ : sources, centralisation, intégrité, conservation, responsabilités.

✍ Exercice 4.10. Plan de comblement ★★★

À partir des angles morts de BÉNOUÉ, proposez un plan de comblement priorisé.

Note

Pour aller plus loin.

➢ RFC 3227 [1] ; loi 2010/012 [13] et 2010/013 [14].

Note

Transition. Collecter ne suffit pas ; il faut corréler : le Chapitre 5 traite du SIEM.

5

LE SIEM

« Le SIEM ne détecte pas ; il rapproche. Ce sont vos règles qui détectent. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 4.

✦ Objectifs du chapitre

- ➢ Définir le SIEM et son rôle dans le SOC.
- ➢ Décrire la chaîne collecte, normalisation, corrélation, alerte.
- ➢ Comprendre la notion de cas d'usage de détection.
- ➢ Distinguer corrélation et simple recherche.
- ➢ Éviter les pièges du volume et du bruit.

Question directrice : un SIEM aurait-il, à lui seul, arrêté l'attaque ?

Beaucoup croient qu'installer un SIEM « rend visible » l'attaque. En réalité, un SIEM sans cas d'usage est un entrepôt de journaux muet. Ce chapitre montre ce qu'un SIEM fait, et ce qu'il ne fait pas sans travail humain.

Plan du chapitre.

1. Qu'est-ce qu'un SIEM (section 5.1).
2. La chaîne de traitement (section 5.2).
3. Les cas d'usage (section 5.3).
4. Corréler, pas seulement chercher (section 5.4).
5. Les pièges (section 5.5).

© *MaletYon*

5.1 Qu'est-ce qu'un SIEM

Définition

SIEM (*Security Information and Event Management*) : plateforme qui collecte les journaux de sources multiples, les normalise, les conserve, et déclenche des alertes lorsque des règles de corrélation reconnaissent un motif suspect.

5.2 La Chaîne de Traitement

Étape	Rôle
Collecte	Recevoir les journaux des sources (agents, syslog, API)
Normalisation	Ramener à un format commun (qui, quoi, quand, où)
Enrichissement	Ajouter contexte (géolocalisation, criticité de l'actif)
Corrélation	Rapprocher plusieurs événements selon une règle
Alerte	Signaler à l'analyste un motif suspect, avec son contexte

Tableau 5.1. La chaîne de traitement d'un SIEM

5.3 Les Cas d'Usage

Définition

Cas d'usage de détection : situation précise que l'on veut détecter, traduite en une ou plusieurs règles sur des sources identifiées. Exemple : « un compte de service se connecte à un poste de travail hors plage horaire habituelle ».

Un SIEM se construit cas d'usage par cas d'usage, en priorité sur les techniques d'attaque les plus probables (ATT&CK). Sans cas d'usage, il ne produit aucune alerte utile.

5.4 Corréler, pas seulement Chercher

Chercher dans les journaux (« trouve-moi les connexions de ce compte ») répond à une question que l'on se pose déjà. **Corréler**, c'est rapprocher automatiquement des événements de sources différentes pour faire émerger une alerte que personne n'a pensé à chercher : une connexion, suivie d'une création de compte, suivie d'un accès à un partage sensible, en quelques minutes.

5.5 Les Pièges

★ Attention

Erreur fréquente. Tout collecter et activer toutes les règles par défaut.

Règle : le volume coûte cher et le bruit noie les vraies alertes. On collecte ce qui sert des cas d'usage, on règle les seuils, on mesure le taux de faux positifs (Chapitre 3).

Scénario Opérationnel · Opération BÉNOUÉ. Le SIEM arrivé trop tard

Constatation. Après l'incident, LiZbiZ déploie un SIEM mutualisé chez NYONG SÉCURITÉ. Rejouées sur les journaux de février, trois règles simples (connexion anormale d'un compte de service, création de compte hors maintenance, service installé à distance) auraient alerté dès le 23 février.

Analyse (confiance élevée). Le SIEM n'aurait rien fait seul : ce sont ces trois cas d'usage, écrits à la main, qui auraient réduit le délai de présence de onze jours à quelques heures.

Application Analyste SOC

Un SIEM se nourrit de cas d'usage. L'analyste ne « regarde » pas le SIEM : il y écrit des cas d'usage, les éprouve, mesure leur bruit et les affine. La valeur est dans les règles, pas dans l'outil.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le SIEM** collecte, normalise, corrèle, alerte.
- **Sans cas d'usage**, il est muet.
- **Corréler** fait émerger ce qu'on n'aurait pas cherché.
- **Le volume et le bruit** sont les pièges.
- **La valeur** est dans les règles, pas dans l'outil.

● Note

Points de contrôle de l'élève. Je sais : définir un SIEM ; décrire sa chaîne ; écrire un cas d'usage ; distinguer corréler et chercher ; éviter le piège du volume.

✍ Exercice 5.1. Chaîne ★☆☆

Remettez dans l'ordre : alerte, collecte, corrélation, normalisation.

✍ Exercice 5.2. Muet ★☆☆

Pourquoi un SIEM sans cas d'usage ne produit-il aucune alerte utile ?

✍ Exercice 5.3. Cas d'usage ★☆☆

Rédigez un cas d'usage en une phrase pour « compte de service sur un poste ordinaire ».

✍ Exercice 5.4. Corréler ★★☆

Donnez un exemple de corrélation à trois événements qui révèle une intrusion.

✍ Exercice 5.5. Bruit ★★☆

Pourquoi activer toutes les règles par défaut nuit-il à la détection ?

✍ Exercice 5.6. BÉNOUÉ ★★☆

Quelles trois règles auraient alerté dès le 23 février ?

✍ Exercice 5.7. Enrichissement ★★☆

Qu'apporte l'enrichissement (criticité de l'actif) à une alerte ?

✍ Exercice 5.8. Chercher ou corréler ★★☆

Classez : « liste les connexions de svc_sauvegarde » ; « alerte si un compte de service accède à un partage sensible après une connexion anormale ».

✍ Exercice 5.9. Catalogue ★★★

Proposez un catalogue de dix cas d'usage prioritaires pour LiZbiZ, reliés à des techniques ATT&CK.

✍ Exercice 5.10. Dimensionnement ★★★

Comment arbitrer entre volume collecté, coût et couverture de détection ?

Note

Pour aller plus loin.

➢ CIS Controls v8 [3] ; MITRE ATT&CK [18].

Note

Transition. À côté du SIEM, des sondes détectent au fil du réseau et des hôtes : le Chapitre 6 traite des IDS/IPS.

6

LA DÉTECTION D'INTRUSION (IDS/IPS)

« Détecter laisse passer pour voir ; prévenir bloque au risque de couper. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 5 ; notions de réseaux.

✦ Objectifs du chapitre

- ➢ Distinguer IDS et IPS, réseau et hôte.
- ➢ Comparer détection par signatures et par anomalies.
- ➢ Comprendre le placement des sondes.
- ➢ Relier les sondes au SIEM.
- ➢ Peser le risque d'un blocage automatique.

Question directrice : fallait-il bloquer automatiquement, au risque de couper la production de Garoua ?

Un IPS aurait pu bloquer la connexion suspecte du 23 février. Mais un blocage mal réglé coupe aussi des flux légitimes. Ce chapitre distingue les sondes, leurs méthodes et leur placement, et pose l'arbitrage entre détecter et bloquer.

Plan du chapitre.

1. IDS et IPS, réseau et hôte (section 6.1).
2. Signatures ou anomalies (section 6.2).
3. Le placement des sondes (section 6.3).
4. Détecter ou bloquer (section 6.4).

© MaletYon

6.1 IDS et IPS, Réseau et Hôte

Sonde	Agit	Observe
IDS	Détecte et alerte, sans bloquer	Le trafic ou l'activité
IPS	Détecte et bloque en ligne	Le trafic ou l'activité
Réseau (NIDS/NIPS)	Sur un point de passage du réseau	Les flux
Hôte (HIDS/HIPS)	Sur une machine	Les processus, fichiers, journaux

Tableau 6.1. Familles de sondes de détection

6.2 Signatures ou Anomalies

Méthode	Principe	Limite
Signatures	Reconnaît des motifs connus	Aveugle à l'inconnu
Anomalies	Signale l'écart à un profil normal	Faux positifs, apprentissage délicat

Tableau 6.2. Deux méthodes de détection

Les deux sont complémentaires : les signatures attrapent le connu à faible bruit, les anomalies ouvrent une chance sur l'inconnu, au prix de faux positifs à régler.

6.3 Le Placement des Sondes

Une sonde réseau ne voit que le trafic qui passe par elle : on la place aux points stratégiques (sortie Internet, cœur de réseau, segment serveurs). Une sonde hôte voit tout de sa machine mais rien des autres. Les alertes des sondes alimentent le SIEM, qui les corrèle avec les journaux (Chapitre 5).

6.4 Détecter ou Bloquer

★ Attention

Erreur fréquente. Mettre tous les IPS en blocage automatique « pour être tranquille ».

Règle : un blocage mal réglé coupe des flux légitimes et peut arrêter la production. On bloque automatiquement le connu à très forte confiance ; on détecte et on fait valider le reste par un analyste.

Scénario Opérationnel · Opération BÉNOUÉ. Détecter d'abord

Constatation. LiZbiZ installe une sonde réseau en sortie et des sondes hôte sur les serveurs. Les sondes sont d'abord en détection, non en blocage.

Analyse (confiance moyenne). Sur un parc sans historique de réglage, commencer en détection évite de couper la production ; le passage au blocage se fait règle par règle, une fois le bruit maîtrisé. Prudence d'abord, au nom de la disponibilité.

Application Analyste SOC et administrateur réseau

Régler avant de bloquer. Le passage d'un IPS en blocage se décide sur mesure : on observe en détection, on mesure les faux positifs, puis on bloque les règles sûres. La disponibilité de la production est un critère de sécurité.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **IDS** alerte, **IPS** bloque ; **réseau** ou **hôte**.
- **Signatures** (le connu) et **anomalies** (l'inconnu) se complètent.
- **Le placement** décide de ce qu'une sonde voit.
- **Les sondes alimentent le SIEM**.
- **Bloquer** se fait avec prudence, règle par règle.

Note

Points de contrôle de l'élève. Je sais : distinguer IDS/IPS et réseau/hôte ; comparer signatures et anomalies ; placer une sonde ; arbitrer entre détecter et bloquer.

Exercice 6.1. IDS ou IPS ★☆☆

Lequel bloque en ligne ? Lequel se contente d'alerter ?

Exercice 6.2. Réseau ou hôte ★☆☆

Quelle sonde voit les processus d'une machine ? Laquelle voit les flux ?

Exercice 6.3. Méthodes ★☆☆

Quelle méthode est aveugle à l'inconnu ? Laquelle produit des faux positifs ?

✍ Exercice 6.4. Placement ★★☆

Où placer une sonde réseau pour voir l'exfiltration vers l'Internet ?

✍ Exercice 6.5. Complémentarité ★★☆

Pourquoi combiner signatures et anomalies ?

✍ Exercice 6.6. Blocage ★★☆

Pourquoi ne pas tout mettre en blocage automatique chez LiZbiZ ?

✍ Exercice 6.7. SIEM ★★☆

Comment les alertes des sondes s'articulent-elles avec le SIEM ?

✍ Exercice 6.8. Angle mort ★★☆

Quel trafic une sonde réseau mal placée laisse-t-elle passer ?

✍ Exercice 6.9. Plan de déploiement ★★★

Proposez le plan de déploiement des sondes pour LiZbiZ (points, détection puis blocage).

✍ Exercice 6.10. Passage au blocage ★★★

Décrivez la démarche pour faire passer une règle d'IPS de la détection au blocage sans risque pour la production.

● Note

Pour aller plus loin.

➢ NIST SP 800-61r2 [4] ; MITRE ATT&CK [18].

● Note

Transition. Sondes et SIEM ne valent que par leurs règles : le Chapitre 7 apprend à en écrire et à les éprouver.

7

ÉCRIRE ET ÉPROUVER UNE RÈGLE DE DÉTECTION

« Une bonne règle se juge à deux nombres :
ce qu'elle attrape, et ce qu'elle dérange pour rien. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitres 5 et 6.

✦ Objectifs du chapitre

- ➢ Formuler une règle de détection en français avant de la coder.
- ➢ Relier chaque règle à une technique ATT&CK et à sa trace.
- ➢ Éprouver une règle : vrais positifs, faux positifs, faux négatifs.
- ➢ Maintenir un catalogue de règles dans le temps.
- ➢ Rédiger la fiche d'une règle.

Question directrice : comment transformer « un compte de service anormal » en une alerte fiable ?

L'idée d'une règle est simple ; la faire fonctionner sans noyer l'analyste l'est moins. Ce chapitre apprend à écrire une règle, à l'éprouver et à la maintenir, à partir des trois cas d'usage de l'opération BÉNOUÉ.

Plan du chapitre.

1. Énoncer avant de coder (section 7.1).
2. Relier à une technique et à sa trace (section 7.2).
3. Éprouver une règle (section 7.3).
4. Maintenir le catalogue (section 7.4).

© MaletYon

7.1 Énoncer avant de Coder

Chaîne de custody

Énoncer une règle

1. **Quoi** : le comportement à détecter, en une phrase.
2. **Source** : le ou les journaux concernés.
3. **Condition** : ce qui déclenche (seuil, enchaînement, contexte).
4. **Exceptions** : les cas légitimes à exclure.
5. **Réponse** : priorité, action attendue de l'analyste.

Exemple : « Alerter si un compte de service ouvre une session interactive sur un poste de travail (source : journaux du domaine, événement de connexion de type 2), hors des comptes et plages de maintenance déclarés. »

7.2 Relier à une Technique et à sa Trace

Cas d'usage (BÉNOUÉ)	Technique ATT&CK	Trace
Compte de service sur un poste	Identifiants valides (usage)	Connexion du domaine
Création de compte hors maintenance	Persistance	Événement de création de compte
Service installé à distance	Mouvement latéral	Événement d'installation de service

Tableau 7.1. Trois règles reliées à ATT&CK [18]

7.3 Éprouver une Règle

Définition

Vrai positif : la règle alerte sur un vrai comportement visé. **Faux positif** : elle alerte à tort. **Faux négatif** : elle laisse passer le comportement visé. On éprouve une règle en la rejouant sur des journaux réels et sur un jeu de test (la technique jouée en laboratoire).

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO d'une règle trop large. Une règle qui collecte et inspecte un trafic très étendu « pour ne rien rater » dégrade la $\mathcal{C}$: - $\mathcal{F}$: + $\mathcal{O}$: 0 : elle augmente la détection (fiabilité) mais expose davantage de données (confidentialité). On cible

la règle sur ce qui est nécessaire.

7.4 Maintenir le Catalogue

Scénario Opérationnel · Opération BÉNOUÉ. Du cas d'usage à la règle éprouvée

Constatation. La règle « compte de service sur un poste » alerte 24 fois en une semaine de test : 3 vrais positifs (comptes réellement mal utilisés), 21 faux positifs (un script de sauvegarde légitime).

Analyse (confiance élevée). En excluant le compte du script de sauvegarde déclaré, les faux positifs tombent à zéro sans perdre les vrais positifs. Une règle n'est utile qu'une fois éprouvée et affinée.

Application Analyste SOC / ingénierie de détection

Une règle vit. L'ingénieur de détection versionne ses règles, note leur technique ATT&CK, mesure leur bruit et les révise après chaque incident. Un catalogue de règles est un actif à entretenir, pas une installation unique.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Énoncer** en français : quoi, source, condition, exceptions, réponse.
- **Relier** chaque règle à une technique ATT&CK et à sa trace.
- **Éprouver** : vrais positifs, faux positifs, faux négatifs.
- **Affiner** par les exceptions, sans perdre les vrais positifs.
- **Maintenir** le catalogue dans le temps.

Note

Points de contrôle de l'élève. Je sais : énoncer une règle ; la relier à ATT&CK ; distinguer les trois cas (VP, FP, FN) ; affiner par exceptions ; entretenir un catalogue.

Exercice 7.1. Énoncer ★☆☆

Énoncez en français la règle « service installé à distance hors maintenance ».

✍ **Exercice 7.2. Trois cas** ★☆☆

Définissez vrai positif, faux positif, faux négatif.

✍ **Exercice 7.3. Technique** ★☆☆

À quelle tactique ATT&CK relier « création de compte hors maintenance » ?

✍ **Exercice 7.4. Affiner** ★★☆

Comment ramener à zéro les 21 faux positifs sans perdre les 3 vrais positifs ?

✍ **Exercice 7.5. Faux négatif** ★★☆

Pourquoi un faux négatif est-il plus grave qu'un faux positif ?

✍ **Exercice 7.6. CRO** ★★☆

Expliquez l'analyse CRO d'une règle trop large.

✍ **Exercice 7.7. Jeu de test** ★★☆

Comment constituer un jeu de test pour éprouver une règle ?

✍ **Exercice 7.8. Fiche de règle** ★★☆

Rédigez la fiche complète d'une des trois règles de BÉNOUÉ.

✍ **Exercice 7.9. Catalogue** ★★★

Organisez un catalogue de règles : versionnage, métadonnées, révision.

✍ **Exercice 7.10. Couverture** ★★★

À partir d'ATT&CK, proposez cinq règles qui augmenteraient la couverture de détection de LiZbiZ.

● **Note**

Pour aller plus loin.

➢ MITRE ATT&CK [18] ; NIST SP 800-61r2 [4].

● **Note**

Transition. La Partie III pose le cadre normatif et juridique de tout ce qui précède : le Chapitre 8 ouvre sur les normes de l'incident et de la preuve.

partie III

Cadre Normatif et Juridique

© MaletYon

8

NORMES DE LA GESTION D'INCIDENT ET DE LA PREUVE

« Une norme ne remplace pas le jugement ;
elle en garantit la méthode et la trace. »

Principe du cours

Niveau : *Fondamental* • Partie II ; notions de gestion de la sécurité.

✦ Objectifs du chapitre

- ➢ Décrire le cycle de gestion d'incident de l'ISO/IEC 27035.
- ➢ Connaître les principes de collecte de preuve de l'ISO/IEC 27037.
- ➢ Situer le guide NIST SP 800-86 et la RFC 3227.
- ➢ Articuler ces référentiels entre eux.
- ➢ Relier chaque norme à une pratique du cours.

Question directrice : quelles normes encadrent ce que LiZbiZ doit faire, du constat à la preuve ?

Face à l'incident, LiZbiZ et NYONG SÉCURITÉ ne partent pas d'une page blanche : des normes internationales fixent le cycle de gestion et les exigences de la preuve. Ce chapitre les présente et montre comment elles s'articulent.

Plan du chapitre.

1. Le cycle ISO/IEC 27035 (section 8.1).
2. La preuve selon l'ISO/IEC 27037 (section 8.2).
3. NIST SP 800-86 et RFC 3227 (section 8.3).
4. Articuler les référentiels (section 8.4).

© *MaletYon*

8.1 Le Cycle ISO/IEC 27035

Définition

ISO/IEC 27035 : norme de gestion des incidents de sécurité de l'information. Elle décrit un cycle en cinq phases : *planifier et préparer* ; *détecter et signaler* ; *évaluer et décider* ; *répondre* ; *tirer les leçons*.

Phase (ISO 27035)	Ce qu'elle recouvre
Planifier et préparer	Politique, rôles, outils, playbooks
Détecter et signaler	Supervision, alertes, point de contact
Évaluer et décider	Qualification, gravité, décision de réponse
Répondre	Confinement, éradication, rétablissement
Tirer les leçons	Retour d'expérience, amélioration

Tableau 8.1. Le cycle en cinq phases de l'ISO/IEC 27035 [11]

8.2 La Preuve selon l'ISO/IEC 27037

Définition

ISO/IEC 27037 : lignes directrices pour l'identification, la collecte, l'acquisition et la préservation des preuves numériques. Elle repose sur trois exigences : **pertinence**, **fiabilité** et **suffisance**, garanties par la traçabilité des actes.

Chaîne de custody

Préserver une preuve (ISO/IEC 27037)

1. Identifier le support et sa volatilité.
2. Acquérir selon l'ordre de volatilité (du plus volatil au plus stable).
3. Calculer un condensat (empreinte) à l'acquisition.
4. Documenter chaque acte : qui, quoi, quand, comment.
5. Conserver en garantissant l'intégrité (chaîne de custody, Chapitre 11).

8.3 NIST SP 800-86 et RFC 3227

Le **NIST SP 800-86** intègre la forensique à la réponse à incident en quatre temps : *collecte*, *examen*, *analyse*, *rapport*. La **RFC 3227** donne les lignes directrices de collecte et d'archivage des preuves, dont le fameux **ordre de volatilité** (mémoire avant disque, disque avant archives).

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Analyse CRO de l'ordre de volatilité. Capturer la mémoire d'abord sert la $\mathcal{C}$: 0 $\mathcal{F}$: + $\mathcal{O}$: + : on fige une trace fugace (fiabilité) exploitable devant un tiers (opposabilité), sans exposer plus que nécessaire. Attendre, c'est perdre la trace et son opposabilité.

8.4 Articuler les Référentiels

Scénario Opérationnel · Opération FARO. Quelle norme pour quel acte

Constatation. Pour l'enquête, M. BIKORO suit l'ISO 27035 (cycle), l'ISO 27037 (préservation), le NIST 800-86 (démarche forensique) et la RFC 3227 (ordre de volatilité).

Analyse (confiance élevée). Les référentiels ne se concurrencent pas : 27035 cadre la gestion, 27037 et RFC 3227 encadrent la preuve, 800-86 relie forensique et réponse. Ensemble, ils garantissent une méthode opposable.

Application Analyste forensique et RSSI

Citer la norme suivie. Dans un rapport, l'analyste indique quelle norme a guidé chaque acte : c'est ce qui rend la démarche vérifiable et opposable. « J'ai acquis selon l'ISO 27037 » vaut mieux que « j'ai copié le disque ».

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **ISO/IEC 27035** : cycle d'incident en cinq phases.
- **ISO/IEC 27037** : pertinence, fiabilité, suffisance de la preuve.
- **NIST 800-86** : collecte, examen, analyse, rapport.
- **RFC 3227** : ordre de volatilité.
- **Les référentiels s'articulent** ; on cite celui que l'on suit.

Note

Points de contrôle de l'élève. Je sais : énoncer les cinq phases de 27035 ; citer les exigences de 27037 ; décrire la démarche 800-86 ; énoncer l'ordre de volatilité ; articuler les référentiels.

✍ Exercice 8.1. Cinq phases ★☆☆

Citez les cinq phases du cycle ISO/IEC 27035 dans l'ordre.

✍ Exercice 8.2. Exigences ★☆☆

Quelles sont les trois exigences de la preuve selon l'ISO/IEC 27037 ?

✍ Exercice 8.3. Volatilité ★☆☆

Dans quel ordre acquérir : disque, mémoire, archives ?

✍ Exercice 8.4. 800-86 ★★☆

Décrivez les quatre temps du NIST SP 800-86 sur l'exemple de FARO.

✍ Exercice 8.5. CRO ★★☆

Expliquez l'analyse CRO de l'ordre de volatilité.

✍ Exercice 8.6. Articulation ★★☆

Quelle norme cadre la gestion ? Laquelle encadre la preuve ?

✍ Exercice 8.7. Condensat ★★☆

Pourquoi calculer un condensat dès l'acquisition ?

✍ Exercice 8.8. Citer la norme ★★☆

Pourquoi « acquis selon l'ISO 27037 » vaut-il mieux que « copié le disque » ?

✍ Exercice 8.9. Démarche ★★★

Rédigez, pour FARO, la démarche d'enquête en reliant chaque acte à sa norme.

✍ Exercice 8.10. Playbook ★★★

Intégrez l'ISO 27035 dans un playbook de réponse au rançongiciel de LiZbiZ.

Note

Pour aller plus loin.

➢ ISO/IEC 27035 [11] ; ISO/IEC 27037 [7] ; NIST SP 800-86 [12] ; RFC 3227 [1].

Note

Transition. Aux normes s'ajoute le droit : le Chapitre 9 traite du cadre juridique camerounais et africain.

9

LE CADRE JURIDIQUE

« Les journaux tracent la frontière entre la faute professionnelle et la bonne foi prouvée. »

Principe du cours

Niveau : *Fondamental* • Chapitre 8 ; notions de droit numérique.

✦ Objectifs du chapitre

- ➢ Connaître la loi camerounaise 2010/012 et la loi 2010/013.
- ➢ Situer la loi de 2024 sur les données personnelles.
- ➢ Comprendre le rôle et les pouvoirs de l'ANTIC.
- ➢ Articuler le droit national avec la Convention de Malabo et celle de Budapest.
- ➢ Déduire les obligations de LiZbiZ en cas d'incident.

Question directrice : qu'est-ce que la loi impose à LiZbiZ le 6 mars au matin ?

L'incident n'est pas qu'un problème technique : il déclenche des obligations. Conserver les traces, signaler à l'ANTIC, notifier une fuite de données : autant de devoirs dont le non-respect engage la responsabilité. Ce chapitre pose le cadre.

Plan du chapitre.

1. La loi 2010/012 et la loi 2010/013 (section 9.1).
2. Les données personnelles (section 9.2).
3. L'ANTIC (section 9.3).
4. Malabo et Budapest (section 9.4).
5. Les obligations de LiZbiZ (section 9.5).

© *MaletYon*

9.1 La Loi 2010/012 et la Loi 2010/013

⚖ Jurisprudence & Droit applicable

La **Loi loi n° 2010/012 du 21 décembre 2010** relative à la cybersécurité et à la cybercriminalité est le texte fondateur : elle réprime l'accès et le maintien frauduleux dans un système, impose la conservation des traces et la coopération avec l'ANTIC. La **Loi loi n° 2010/013** régit les communications électroniques et les obligations des opérateurs. Les articles précis se lisent dans le texte publié au Journal officiel ; le cours n'en cite que des éléments vérifiés.

9.2 Les Données Personnelles

⚖ Jurisprudence & Droit applicable

La **Loi loi n° 2024/017 du 23 décembre 2024** régit la protection des données à caractère personnel. Une fuite de données clients, comme celle redoutée dans l'opération GAROUA, relève de ce texte : information de l'autorité, des personnes concernées, et documentation de la violation.

9.3 L'ANTIC

■ Définition

ANTIC (Agence Nationale des Technologies de l'Information et de la Communication) : autorité camerounaise de la sécurité électronique. Elle reçoit les signalements d'incidents, peut auditer, coordonne la réponse nationale et coopère avec le parquet.

9.4 Malabo et Budapest

Instrument	Portée
Convention de Malabo (UA, 2014)	Cadre continental : cybersécurité, cybercriminalité, données personnelles
Convention de Budapest (2001)	Cadre international : infractions, preuve électronique, coopération

Tableau 9.1. Deux instruments supranationaux [5], [19]

9.5 Les Obligations de LiZbiZ

Scénario Opérationnel · Opération GAROUA. Les devoirs du 6 mars

Constatation. LiZbiZ subit un rançongiciel avec exfiltration probable de données clients. Elle doit : conserver les journaux, signaler l'incident à l'ANTIC, documenter la violation, et, si des données personnelles sont touchées, en informer l'autorité et les personnes.

Analyse (confiance élevée). Ne pas disposer de journaux exploitables affaiblirait la position de LiZbiZ : la preuve de sa diligence repose sur les traces. Le droit transforme la supervision en obligation, et le forensique en moyen de preuve.

Application RSSI et juriste TIC

Connaître ses obligations avant l'incident. Le RSSI prépare, à froid, la liste des signalements et notifications dus, avec leurs destinataires et délais. En pleine crise, on applique une procédure, on ne découvre pas le droit.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Loi 2010/012** : accès frauduleux, conservation, coopération.
- **Loi 2024/017** : protection des données personnelles.
- **L'ANTIC** reçoit les signalements et coordonne.
- **Malabo et Budapest** encadrent au niveau continental et international.
- **Les journaux** fondent la preuve de la diligence.

Note

Points de contrôle de l'élève. Je sais : citer les lois 2010/012, 2010/013, 2024/017 ; décrire l'ANTIC ; situer Malabo et Budapest ; énoncer les obligations de LiZbiZ.

Exercice 9.1. La loi fondatrice ★☆☆

Quel texte camerounais fonde le droit de la cybersécurité ? De quelle année ?

Exercice 9.2. L'ANTIC ★☆☆

Citez trois pouvoirs de l'ANTIC.

✍ Exercice 9.3. Données ★☆☆

Quel texte protège les données personnelles au Cameroun ?

✍ Exercice 9.4. Malabo ★★☆

Qu'apporte la Convention de Malabo par rapport au droit national ?

✍ Exercice 9.5. Preuve de diligence ★★☆

Pourquoi les journaux tracent-ils la frontière entre faute et bonne foi ?

✍ Exercice 9.6. Notifications ★★☆

Quelles notifications LiZbiZ doit-elle envisager le 6 mars ?

✍ Exercice 9.7. Budapest ★★☆

En quoi la Convention de Budapest facilite-t-elle la coopération internationale ?

✍ Exercice 9.8. À froid ★★☆

Pourquoi préparer la liste des obligations avant l'incident ?

✍ Exercice 9.9. Procédure de signalement ★★★

Rédigez la procédure de signalement à l'ANTIC pour LiZbiZ : déclencheur, contenu, délai, destinataire.

✍ Exercice 9.10. Note juridique ★★★

Rédigez une note qui récapitule les obligations légales de LiZbiZ en cas d'incident majeur.

● Note

Pour aller plus loin.

- Lois 2010/012 [13], 2010/013 [14], 2024/017 [15].
- Convention de Malabo [19] ; Convention de Budapest [5].

● Note

Transition. Normes et droit convergent sur une question : une trace est-elle recevable ? C'est l'objet du Chapitre 10.

10

L'ADMISSIBILITÉ DE LA PREUVE NUMÉRIQUE

« Une preuve que l'on ne peut pas défendre
ne vaut pas mieux qu'une preuve que l'on n'a pas. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 8 et 9.

✦ Objectifs du chapitre

- ➢ Définir l'admissibilité et ses conditions.
- ➢ Comprendre l'intégrité, l'authenticité et la traçabilité.
- ➢ Relier l'admissibilité au Trilemme CRO.
- ➢ Reconnaître ce qui détruit une preuve.
- ➢ Préparer une preuve opposable dès l'acquisition.

Question directrice : la preuve recueillie chez LiZbiZ tiendrait-elle devant un tiers ?

Recueillir une trace est une chose ; pouvoir s'en prévaloir devant la direction, l'ANTIC ou un juge en est une autre. Ce chapitre pose les conditions de l'admissibilité et montre comment une manipulation imprudente détruit une preuve pourtant exacte.

Plan du chapitre.

1. Qu'est-ce que l'admissibilité (section 10.1).
2. Intégrité, authenticité, traçabilité (section 10.2).
3. Le Trilemme CRO appliqué (section 10.3).
4. Ce qui détruit une preuve (section 10.4).

© *MaletYon*

10.1 Qu'est-ce que l'Admissibilité

■ Définition

Admissibilité : aptitude d'une preuve à être reçue et prise en compte par un tiers (direction, autorité, juge). Elle ne tient pas à la seule exactitude de la trace, mais à la *manière* dont elle a été recueillie, conservée et documentée.

10.2 Intégrité, Authenticité, Traçabilité

Condition	Ce qu'elle exige
Intégrité	La preuve n'a pas été altérée depuis l'acquisition (condensat).
Authenticité	La preuve est bien ce qu'elle prétend être, de la source déclarée.
Traçabilité	Chaque manipulation est documentée (chaîne de custody).
Licéité	La collecte respecte le droit (autorisation, proportionnalité).

Tableau 10.1. Conditions de l'admissibilité

10.3 Le Trilemme CRO Appliqué

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

L'admissibilité est l'opposabilité. La dimension O du Trilemme est précisément l'admissibilité : une preuve opposable est une preuve admissible. La F (fiabilité) recouvre l'intégrité et l'authenticité ; la C (confidentialité) impose de ne saisir que le nécessaire. Une bonne pratique vise $\mathcal{C}$: 0 $\mathcal{F}$: + $\mathcal{O}$: + à chaque acte.

10.4 Ce qui Détruit une Preuve

★ Attention

Violation typique. Travailler directement sur l'original, sans condensat ni copie.

Règle : on travaille sur une copie vérifiée par condensat, on documente chaque acte, on ne modifie jamais l'original. Une preuve manipulée sans trace est perdue, même si son contenu est exact.

Scénario Opérationnel · Opération FARO. La preuve sauvée de justesse

Constatation. Un technicien de LiZbiZ, de bonne foi, avait redémarré le serveur `FS-01` et commencé à « nettoyer » avant l'arrivée de M. BIKORO. La mémoire vive était perdue ; le disque, lui, n'avait pas encore été écrasé.

Analyse (confiance élevée). Le redémarrage a détruit une preuve volatile (mémoire) et a failli compromettre le disque. M. BIKORO a figé l'état restant, calculé les condensats et documenté la chaîne : le disque reste opposable, la mémoire est perdue. La leçon : ne rien toucher avant d'avoir figé.

Application Analyste forensique

Figer avant de comprendre. L'analyste résiste à la tentation d'« aller voir » sur le système vivant : chaque action non documentée dégrade l'opposabilité. On fige, on copie, on vérifie, puis on analyse la copie.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'admissibilité** tient à la manière, pas à la seule exactitude.
- **Intégrité, authenticité, traçabilité, licéité** : les conditions.
- **L'opposabilité** du CRO *est* l'admissibilité.
- **Travailler sur l'original** détruit la preuve.
- **Figer avant de comprendre.**

Note

Points de contrôle de l'élève. Je sais : définir l'admissibilité ; citer ses conditions ; la relier au CRO ; reconnaître ce qui détruit une preuve ; préparer une preuve opposable.

✍ Exercice 10.1. Définir ★☆☆

L'admissibilité tient-elle à l'exactitude de la trace ou à la manière de la recueillir ?

✍ Exercice 10.2. Conditions ★☆☆

Citez les quatre conditions de l'admissibilité.

✍ Exercice 10.3. Condensat ★☆☆

À quoi sert le condensat (empreinte) d'une preuve ?

✍ Exercice 10.4. CRO ★★☆

Pourquoi dit-on que l'opposabilité du CRO est l'admissibilité ?

✍ Exercice 10.5. FARO ★★☆

Quelle preuve le redémarrage a-t-il détruite ? Laquelle a été sauvée ?

✍ Exercice 10.6. L'original ★★☆

Pourquoi ne jamais travailler sur l'original ?

✍ Exercice 10.7. Bonne foi ★★☆

Le technicien était de bonne foi. Pourquoi son geste était-il néanmoins dommageable ?

✍ Exercice 10.8. Licéité ★★☆

En quoi une collecte illicite compromet-elle l'admissibilité ?

✍ Exercice 10.9. Note de première intervention ★★★

Rédigez la consigne de première intervention à afficher près des serveurs de LiZbiZ (« que faire, que ne pas faire »).

✍ Exercice 10.10. Dossier de preuve ★★★

Décrivez le dossier qui accompagne une preuve pour la rendre opposable.

Note

Pour aller plus loin.

➢ ISO/IEC 27037 [7] ; RFC 3227 [1].

Note

Transition. La Partie IV entre dans la pratique de l'enquête : le Chapitre 11 pose les fondements du forensique et la chaîne de custody.

partie IV

L'Analyse Forensique

© MaletYon

11

FONDEMENTS DU FORENSIQUE ET CHAÎNE DE CUSTODY

> « L'enquêteur ne cherche pas à avoir raison ;
> il cherche à pouvoir le prouver. »
>
> — Principe du cours

Niveau : *Fondamental* • Partie III.

✦ Objectifs du chapitre

- ➢ Définir l'analyse forensique et ses principes.
- ➢ Comprendre l'ordre de volatilité et la copie vérifiée.
- ➢ Tenir une chaîne de custody.
- ➢ Qualifier un artefact.
- ➢ Préserver l'opposabilité à chaque étape.

Question directrice : par où commence une enquête propre sur FS-01 ?

Devant un serveur compromis, la tentation est d'« aller voir ». Le forensique impose l'inverse : figer, copier, documenter, puis analyser une copie. Ce chapitre pose les fondements et la chaîne de custody.

Plan du chapitre.

1. Qu'est-ce que le forensique (section 11.1).
2. L'ordre de volatilité (section 11.2).
3. La copie vérifiée (section 11.3).
4. La chaîne de custody (section 11.4).
5. Qualifier un artefact (section 11.5).

© MaletYon

11.1 Qu'est-ce que le Forensique

Définition

Analyse forensique : recherche méthodique, documentée et opposable des traces laissées par un événement sur les systèmes, afin d'établir ce qui s'est passé, comment, et par qui, dans le respect de l'intégrité des preuves.

11.2 L'Ordre de Volatilité

Chaîne de custody

Acquérir selon l'ordre de volatilité (RFC 3227)

1. Mémoire vive et état du système (processus, connexions).
2. Fichiers temporaires et données de session.
3. Disque (systèmes de fichiers).
4. Journaux distants et configuration.
5. Supports d'archives.

On capture d'abord ce qui disparaît le plus vite. Un redémarrage détruit la mémoire : d'où la règle « ne rien toucher avant d'avoir figé » (Chapitre 10).

11.3 La Copie Vérifiée

On n'analyse jamais l'original : on en fait une **copie bit à bit**, dont on calcule un **condensat** (empreinte). Le même condensat sur l'original et la copie prouve que la copie est fidèle et que l'original n'a pas changé. Toute l'analyse se fait sur la copie.

11.4 La Chaîne de Custody

Chaîne de custody

Tenir la chaîne de custody

1. Identifier chaque pièce (numéro, description, condensat).
2. Consigner chaque transfert : qui, à qui, quand, pourquoi.
3. Protéger physiquement et logiquement les pièces.
4. Ne jamais laisser de trou dans la continuité de la détention.
5. Joindre la chaîne au dossier de preuve.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

La chaîne de custody sert l'opposabilité. Une pièce dont la détention présente un trou devient contestable : $\mathcal{C}$: 0 $\mathcal{F}$: 0 $\mathcal{O}$: -. La continuité documentée est ce qui rend la preuve opposable devant un tiers.

11.5 Qualifier un Artefact

Artefact · Journal de connexion de FS-01

Nature : journal d'authentification extrait de la copie du disque de `FS-01`. **Source :** copie vérifiée (condensat au dossier). **Pertinence :** contient les connexions du compte de service suspect. **Fiabilité :** intègre (condensat), horodatage à recaler (écart connu de 40 min). **Opposabilité :** chaîne de custody continue.

Application Analyste forensique

Documenter est enquêter. Pour l'analyste, la documentation n'est pas une formalité postérieure : c'est une partie de l'acte d'enquête. Un geste non documenté est un geste perdu.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le forensique** établit les faits de façon opposable.
- **L'ordre de volatilité** : du plus fugace au plus stable.
- **La copie vérifiée** par condensat remplace l'original.
- **La chaîne de custody** assure la continuité de la détention.
- **Un artefact** se qualifie (nature, source, pertinence, fiabilité, opposabilité).

● Note

Points de contrôle de l'élève. Je sais : définir le forensique ; énoncer l'ordre de volatilité ; faire une copie vérifiée ; tenir une chaîne de custody ; qualifier un artefact.

✍ Exercice 11.1. Volatilité ★☆☆

Classez du plus volatil au plus stable : disque, mémoire vive, archives.

✍ Exercice 11.2. Copie ★☆☆

Pourquoi analyse-t-on une copie et non l'original ?

✍ Exercice 11.3. Custody ★☆☆

Qu'est-ce qu'un « trou » dans la chaîne de custody ?

✍ Exercice 11.4. Condensat ★★☆

Comment un condensat prouve-t-il qu'une copie est fidèle ?

✍ Exercice 11.5. CRO ★★☆

Pourquoi un trou de custody dégrade-t-il l'opposabilité ?

✍ Exercice 11.6. Artefact ★★☆

Qualifiez un artefact de votre choix de l'opération FARO (cinq rubriques).

✍ Exercice 11.7. Horloge ★★☆

Comment traiter l'écart d'horloge de 40 min dans l'analyse ?

✍ Exercice 11.8. Documentation ★★☆

Pourquoi un geste non documenté est-il « perdu » ?

✍ Exercice 11.9. Procédure d'acquisition ★★★

Rédigez la procédure d'acquisition du serveur `FS-01`, dans l'ordre de volatilité.

✍ Exercice 11.10. Formulaire de custody ★★★

Concevez le formulaire de chaîne de custody de LiZbiZ.

● Note

Pour aller plus loin.

➢ ISO/IEC 27037 [7] ; RFC 3227 [1] ; NIST SP 800-86 [12].

● Note

Transition. Le premier terrain d'enquête est le disque : le Chapitre 12 traite du forensique système.

12

FORENSIQUE SYSTÈME

« Le disque garde la mémoire de ce que l'utilisateur croyait avoir effacé. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 11 ; administration Windows et Linux.

✦ Objectifs du chapitre

- ➢ Identifier les artefacts système utiles sous Windows et Linux.
- ➢ Reconstituer une chronologie à partir des horodatages.
- ➢ Repérer les traces de persistance et d'exécution.
- ➢ Distinguer suppression logique et effacement réel.
- ➢ Rédiger un constat système.

Question directrice : que révèle le disque de FS-01 sur les onze jours ?

Le disque de `FS-01` contient les traces du passage de l'attaquant : comptes créés, services installés, programmes exécutés, fichiers consultés. Ce chapitre apprend à les lire et à en tirer une chronologie opposable.

Plan du chapitre.

1. Les artefacts Windows (section 12.1).
2. Les artefacts Linux (section 12.2).
3. La chronologie (section 12.3).
4. Suppression et récupération (section 12.4).

© MaletYon

12.1 Les Artefacts Windows

Artefact	Ce qu'il révèle
Journaux d'événements	Connexions, comptes, services, tâches
Base de registre	Programmes au démarrage, périphériques branchés
Traces d'exécution	Programmes lancés, fréquence, dates
Fichiers récents, raccourcis	Documents ouverts, chemins
Fichier d'échange, clichés	Fragments de mémoire, versions antérieures

Tableau 12.1. Artefacts forensiques Windows

12.2 Les Artefacts Linux

Artefact	Ce qu'il révèle
Journaux système	Authentifications, sudo, démons
Historique des interpréteurs	Commandes saisies
Tâches planifiées (cron)	Persistance, exécutions régulières
Horodatages des fichiers	Accès, modification, changement de métadonnées
Comptes et clés	Comptes ajoutés, clés d'accès déposées

Tableau 12.2. Artefacts forensiques Linux

12.3 La Chronologie

Chaîne de custody

Construire une chronologie (*timeline*)

1. Rassembler les horodatages de tous les artefacts.
2. Recaler les horloges (écarts connus).
3. Ordonner les événements et repérer les enchaînements.
4. Distinguer le certain (trace) du probable (interprétation).
5. Dater chaque étape de l'attaque.

Scénario Opérationnel · Opération FARO. Onze jours reconstitués

Constatation. La chronologie du disque de `FS-01` établit : 23 février, connexion du compte `svc_sauvegarde` à 2 h 14 ; 24 février, création du compte `svc_maj2` ; 1er mars, installation du service `WinUpd32` ; 4 mars, accès massif aux partages ; 6 mars, chiffrement.

Analyse (confiance élevée pour les traces, moyenne pour les intentions). Les horodatages, recalés, dessinent une progression cohérente. On distingue ce qui est tracé (les événements) de ce qu'on en déduit (le but de l'attaquant).

12.4 Suppression et Récupération

Supprimer un fichier ne l'efface pas : le système marque l'espace comme réutilisable, mais les données subsistent jusqu'à réécriture. D'où la possibilité de **récupérer** des fichiers supprimés, tant qu'ils n'ont pas été écrasés. L'attaquant qui « nettoie » laisse souvent des traces récupérables.

Application Analyste forensique

Séparer le tracé du déduit. Dans un constat système, l'analyste écrit d'abord ce que la trace montre, puis, à part, ce qu'il en déduit, avec un niveau de confiance. C'est le cœur de la méthode constatation/analyse.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Windows et Linux** laissent des artefacts riches.
- **La chronologie** relie les horodatages recalés.
- **On date** chaque étape de l'attaque.
- **Supprimer n'est pas effacer** : récupération possible.
- **On sépare** le tracé du déduit.

Note

Points de contrôle de l'élève. Je sais : citer les artefacts Windows et Linux ; construire une chronologie ; dater une attaque ; expliquer la récupération ; séparer trace et interprétation.

✍ Exercice 12.1. Artefact Windows ★☆☆

Quel artefact Windows révèle les programmes lancés au démarrage ?

✍ Exercice 12.2. Artefact Linux ★☆☆

Quel artefact Linux révèle les commandes saisies ?

✍ Exercice 12.3. Suppression ★☆☆

Pourquoi un fichier supprimé peut-il être récupéré ?

✍ Exercice 12.4. Chronologie ★★☆

À partir des faits de FARO, dressez la chronologie des onze jours.

✍ Exercice 12.5. Recaler ★★☆

Comment l'écart d'horloge de 40 min modifie-t-il la chronologie ?

✍ Exercice 12.6. Tracé ou déduit ★★☆

Classez : « le service WinUpd32 a été installé le 1er mars » ; « l'attaquant cherchait la persistance ».

✍ Exercice 12.7. Persistance ★★☆

Quels artefacts trahissent une persistance sous Windows ? Sous Linux ?

✍ Exercice 12.8. Nettoyage ★★☆

Pourquoi le « nettoyage » de l'attaquant laisse-t-il souvent des traces ?

✍ Exercice 12.9. Constat système ★★★

Rédigez un constat système complet pour l'installation de `WinUpd32`.

✍ Exercice 12.10. Plan d'analyse ★★★

Proposez un plan d'analyse du disque de `FS-01`, des artefacts à la chronologie.

● Note

Pour aller plus loin.

➢ NIST SP 800-86 [12] ; ISO/IEC 27037 [7].

Note

Transition. Le disque ne dit pas tout : la mémoire vive garde ce qui n'a jamais été écrit sur disque. Le Chapitre 13 traite du forensique mémoire.

13

FORENSIQUE MÉMOIRE

« La mémoire vive est le seul témoin qui dit la vérité du moment présent
et meurt dès qu'on éteint. »

Principe du cours

Niveau : *Expert* • Chapitre 12.

✦ Objectifs du chapitre

- ➢ Comprendre pourquoi et quand capturer la mémoire vive.
- ➢ Identifier ce que la mémoire révèle et que le disque ignore.
- ➢ Décrire l'acquisition et ses précautions.
- ➢ Repérer les traces d'exécution en mémoire.
- ➢ Mesurer le coût d'un redémarrage imprudent.

Question directrice : qu'a-t-on perdu en redémarrant FS-01 ?

En redémarrant le serveur, le technicien a effacé la mémoire vive. Ce chapitre montre ce qu'elle contenait, pourquoi elle prime dans l'ordre de volatilité, et comment on la capture quand elle est encore là.

Plan du chapitre.

1. Pourquoi la mémoire (section 13.1).
2. Ce qu'elle révèle (section 13.2).
3. L'acquisition (section 13.3).
4. Le coût du redémarrage (section 13.4).

© MaletYon

13.1 Pourquoi la Mémoire

La mémoire vive contient l'état réel du système au moment présent : processus en cours, connexions réseau ouvertes, clés et secrets déchiffrés, code malveillant qui ne touche jamais le disque. C'est pourquoi elle vient en tête de l'ordre de volatilité (Chapitre 11) : elle disparaît à l'extinction.

13.2 Ce qu'elle Révèle

Élément en mémoire	Intérêt pour l'enquête
Processus en cours	Code malveillant actif, parent suspect
Connexions réseau	Vers où le système parlait (exfiltration, pilotage)
Secrets déchiffrés	Clés, mots de passe, jetons en clair
Code injecté	Programme présent en mémoire mais absent du disque
Commandes récentes	Ce que l'attaquant faisait à l'instant

Tableau 13.1. Ce que révèle la mémoire vive

13.3 L'Acquisition

Chaîne de custody

Acquérir la mémoire vive

1. Agir sur le système vivant, avant toute extinction.
2. Utiliser un outil d'acquisition à empreinte minimale, documenté.
3. Écrire la capture sur un support externe, jamais sur le disque analysé.
4. Calculer le condensat de la capture.
5. Consigner l'acte dans la chaîne de custody.

Γ_{CRO} **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Capturer la mémoire, un arbitrage CRO. L'acquisition touche nécessairement le système vivant : elle laisse une empreinte $\mathcal{C}$: 0 $\mathcal{F}$: - $\mathcal{O}$: +. On accepte une légère altération (fiabilité) pour sauver une trace unique et opposable (opposabilité), et on la documente pour la rendre défendable.

13.4 Le Coût du Redémarrage

Scénario Opérationnel · Opération FARO. Ce que la mémoire aurait dit

Constatation. La mémoire de `FS-01`, perdue au redémarrage, aurait vraisemblablement contenu : le processus de chiffrement actif, la connexion d'exfiltration ouverte, et peut-être la clé de chiffrement en clair.

Analyse (confiance moyenne). Sans la mémoire, l'enquête a dû reconstituer ces éléments indirectement, à partir du disque et du réseau : plus long, moins complet. La clé en clair, si elle avait été capturée, aurait pu éviter de payer la rançon. Le redémarrage a coûté cher.

Application Analyste forensique et analyste SOC

Capturer la mémoire d'abord. Face à un système compromis encore allumé, le réflexe est de capturer la mémoire avant tout autre geste. Éteindre « pour arrêter l'attaque » peut détruire la preuve qui aurait permis de la comprendre.

À retenir

Ce qu'il faut retenir de ce chapitre :

- **La mémoire vive** contient l'état réel, et meurt à l'extinction.
- **Elle révèle** processus, connexions, secrets, code injecté.
- **On la capture** sur le système vivant, vers un support externe.
- **L'acquisition** est un arbitrage CRO documenté.
- **Un redémarrage** détruit cette preuve unique.

Note

Points de contrôle de l'élève. Je sais : expliquer la primauté de la mémoire ; citer ce qu'elle révèle ; décrire son acquisition ; analyser le CRO de l'acquisition ; mesurer le coût d'un redémarrage.

Exercice 13.1. Pourquoi d'abord ★☆☆

Pourquoi la mémoire vient-elle en tête de l'ordre de volatilité ?

Exercice 13.2. Révélations ★☆☆

Citez trois éléments que la mémoire révèle et que le disque ignore.

✍ Exercice 13.3. Support ★☆☆

Sur quel support écrit-on la capture mémoire ? Pourquoi pas le disque analysé ?

✍ Exercice 13.4. CRO ★★☆

Expliquez l'arbitrage CRO de l'acquisition mémoire.

✍ Exercice 13.5. FARO ★★☆

Qu'aurait pu contenir la mémoire de `FS-01` ? Qu'a coûté sa perte ?

✍ Exercice 13.6. Code injecté ★★☆

Pourquoi un code injecté peut-il être invisible sur le disque ?

✍ Exercice 13.7. Éteindre ★★☆

« Il faut éteindre pour arrêter l'attaque. » Discutez.

✍ Exercice 13.8. Empreinte ★★☆

Pourquoi documente-t-on l'empreinte laissée par l'outil d'acquisition ?

✍ Exercice 13.9. Procédure ★★★

Rédigez la procédure de capture mémoire de première intervention pour LiZbiZ.

✍ Exercice 13.10. Consigne ★★★

Rédigez la consigne « système compromis allumé : que faire en premier ? ».

● Note

Pour aller plus loin.

➢ NIST SP 800-86 [12] ; RFC 3227 [1].

● Note

Transition. Reste la troisième scène : le réseau, qui garde la trace des échanges. Le Chapitre 14 traite du forensique réseau.

14

FORENSIQUE RÉSEAU

« Les fichiers mentent parfois ; les flux, rarement. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 13 ; notions de réseaux (TCP/IP).

✦ Objectifs du chapitre

- ➢ Identifier les sources de traces réseau (flux, journaux, DNS).
- ➢ Repérer une exfiltration et un canal de pilotage.
- ➢ Lire des enregistrements de flux exportés.
- ➢ Relier les traces réseau à la chronologie système.
- ➢ Rédiger un constat réseau.

Question directrice : où sont partis les 40 Go, et par quel canal l'attaquant pilotait-il ?

L'exfiltration et le pilotage laissent des traces réseau : connexions sortantes inhabituelles, requêtes DNS répétées, volumes anormaux. Ce chapitre apprend à les lire, à partir des journaux de flux exportés (le bureau d'analyse n'a pas d'outil de capture graphique).

Plan du chapitre.

1. Les sources de traces réseau (section 14.1).
2. Exfiltration et pilotage (section 14.2).
3. Lire des flux exportés (section 14.3).
4. Recouper avec le système (section 14.4).

© MaletYon

14.1 Les Sources de Traces Réseau

Source	Ce qu'elle révèle
Journaux de flux (pare-feu)	Qui parle à qui, quand, combien
Journaux du mandataire web	Destinations web, volumes, agents
Journaux DNS	Noms résolus, requêtes répétées ou suspectes
Journaux d'authentification distante	Accès VPN, bureau à distance

Tableau 14.1. Sources de traces réseau

★ Attention

Contrainte du cours. Le bureau d'analyse de NDAP SUKULU ne dispose pas d'outil de capture graphique.

Règle : on travaille sur des *journaux de flux exportés* (au format tableur), ce qui suffit à établir les faits et reste parfaitement opposable. L'essentiel n'est pas l'outil, mais la lecture méthodique.

14.2 Exfiltration et Pilotage

Deux signatures réseau trahissent une intrusion active : l'**exfiltration** (un volume sortant anormal vers une destination inhabituelle) et le **canal de pilotage** (de petites connexions régulières vers un serveur distant, qui commandent le code malveillant). Les deux se repèrent dans les journaux de flux.

14.3 Lire des Flux Exportés

☑ Chaîne de custody

Analyser des journaux de flux

1. Agréger par couple source-destination et par volume.
2. Repérer les destinations externes inhabituelles.
3. Repérer les connexions régulières de faible volume (pilotage).
4. Relever les pics de volume sortant (exfiltration).
5. Recaler les horodatages sur la chronologie système.

Scénario Opérationnel · Opération FARO. Les 40 Go de la nuit du 4 mars

Constatation. Les journaux de flux montrent, dans la nuit du 4 mars, un transfert sortant de 40 Go depuis `FS-01` vers une adresse externe, précédé, depuis le 24 février, de petites connexions régulières (toutes les 10 minutes) vers la même adresse.

Analyse (confiance élevée). Les petites connexions régulières constituent le canal de pilotage ; le transfert de 40 Go, l'exfiltration. Les dates recoupent la chronologie système (création du compte le 24, accès aux partages le 4). Le faisceau est cohérent.

14.4 Recouper avec le Système

Une trace réseau isolée prouve peu ; recoupée avec le disque et la mémoire, elle devient un faisceau solide. La force de l'enquête tient à la convergence des trois scènes (système, mémoire, réseau) sur une même chronologie.

Artefact · Flux d'exfiltration du 4 mars

Nature : enregistrement de flux (journal du pare-feu, exporté). **Source :** copie du journal (condensat au dossier). **Pertinence :** transfert de 40 Go de `FS-01` vers une adresse externe. **Fiabilité :** intègre, horodatage recalé. **Opposabilité :** chaîne de custody continue, recoupé avec la chronologie système.

Application Analyste forensique et analyste SOC

Faire converger les scènes. L'analyste ne se contente pas d'une source : il recoupe réseau, système et mémoire. Une conclusion tenue par une seule trace est fragile ; tenue par trois convergentes, elle est opposable.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Flux, mandataire, DNS** : les sources réseau.
- **Exfiltration** (gros volume sortant) et **pilotage** (petites connexions régulières).
- **Des journaux de flux exportés** suffisent à établir les faits.
- **On recoupe** réseau, système et mémoire.
- **La convergence** fait la force de la preuve.

Note

Points de contrôle de l'élève. Je sais : citer les sources réseau ; reconnaître exfiltration et pilotage ; lire des flux exportés ; recouper avec la chronologie ; rédiger un constat réseau.

✍ Exercice 14.1. Sources ★☆☆

Quelle source révèle le volume d'un transfert sortant ? Les noms résolus ?

✍ Exercice 14.2. Exfiltration ★☆☆

Quelle signature réseau trahit une exfiltration ?

✍ Exercice 14.3. Pilotage ★☆☆

Comment se repère un canal de pilotage dans les flux ?

✍ Exercice 14.4. Sans capture ★★☆

Pourquoi des journaux de flux exportés suffisent-ils, sans capture graphique ?

✍ Exercice 14.5. FARO ★★☆

Dans FARO, distinguez le canal de pilotage de l'exfiltration.

✍ Exercice 14.6. Recouper ★★☆

Comment les flux du 4 mars recoupent-ils la chronologie système ?

✍ Exercice 14.7. Faisceau ★★☆

Pourquoi une trace réseau isolée prouve-t-elle peu ?

✍ Exercice 14.8. Constat réseau ★★☆

Rédigez le constat du flux d'exfiltration du 4 mars.

✍ Exercice 14.9. Analyse de flux ★★★

À partir d'un journal de flux exporté, proposez la démarche pour isoler l'exfiltration.

✍ Exercice 14.10. Convergence ★★★

Construisez le faisceau de preuves de FARO en faisant converger les trois scènes.

Note

Pour aller plus loin.

➢ RFC 3227 [1] ; NIST SP 800-86 [12] ; MITRE ATT&CK [18].

Note

Transition. L'enquête établie, il faut agir : la Partie V traite de la réponse à incident, à commencer par son cycle (Chapitre 15).

partie V

La Réponse à Incident

© MaletYon

15

LE CYCLE DE RÉPONSE À INCIDENT

« La réponse se prépare à froid ;
en pleine crise, on applique, on n'improvise pas. »

Principe du cours

Niveau : *Fondamental* • Chapitre 8.

✦ Objectifs du chapitre

- ➢ Décrire le cycle de réponse (ISO 27035, NIST 800-61r2).
- ➢ Classer un incident par gravité et fixer les délais.
- ➢ Comprendre le rôle de la préparation.
- ➢ Distinguer confinement, éradication, rétablissement.
- ➢ Articuler réponse et forensique sans les opposer.

Question directrice : le 6 mars à 7 h 15, que faut-il faire, et dans quel ordre ?

Devant l'incident, l'urgence pousse à tout faire en même temps. Le cycle de réponse impose un ordre : qualifier, décider, contenir, éradiquer, rétablir, apprendre. Ce chapitre le pose, avec les délais par gravité.

Plan du chapitre.

1. Le cycle (section 15.1).
2. Classer par gravité (section 15.2).
3. La préparation (section 15.3).
4. Réponse et forensique (section 15.4).

© *MaletYon*

15.1 Le Cycle

Étape	Ce qu'on y fait
Préparer	Politique, rôles, playbooks, outils, astreinte
Détecter et qualifier	Confirmer l'incident, évaluer la gravité
Contenir	Limiter la propagation sans détruire la preuve
Éradiquer	Supprimer la cause et la présence de l'attaquant
Rétablir	Restaurer le service à partir de sauvegardes vérifiées
Apprendre	Retour d'expérience, amélioration (Partie VI)

Tableau 15.1. Le cycle de réponse [4], [11]

15.2 Classer par Gravité

Gravité	Exemple	Délai de prise en charge
Critique	Rançongiciel, arrêt de production	Moins d'une heure, astreinte
Élevée	Compromission d'un compte à privilèges	Moins de 4 heures
Moyenne	Poste infecté isolé	Moins de 24 heures
Faible	Tentative bloquée	Moins de 72 heures

Tableau 15.2. Grille de gravité et délais (LiZbiZ)

15.3 La Préparation

La préparation est la phase la plus déterminante : la qualité de la réponse se joue avant l'incident. Elle comprend les rôles, les coordonnées, les playbooks (rançongiciel, hameçonnage, fuite de données), les sauvegardes vérifiées et les droits d'accès d'urgence. Un incident révèle toujours l'état de la préparation.

★ Attention

Erreur fréquente. Rétablir avant d'éradiquer.

Règle : restaurer un service alors que l'attaquant est toujours présent le ramène aussitôt. On éradique (et on vérifie l'éradication) avant de rétablir.

15.4 Réponse et Forensique

Scénario Opérationnel · Opération MAYO. L'ordre tenu

Constatation. Le 6 mars, après qualification (critique), Mme NGASSA décide : isoler les systèmes atteints (confinement), capturer les preuves avant toute remise en service, éradiquer le compte `svc_maj2` et le service `WinUpd32`, puis rétablir depuis des sauvegardes vérifiées hors ligne.

Analyse (confiance élevée). Le confinement a précédé le rétablissement ; la capture des preuves (Partie IV) a été insérée avant l'éradication. Réponse et forensique ne s'opposent pas : on contient, on fige, puis on nettoie.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

Contenir sans détruire la preuve. Isoler une machine du réseau préserve la preuve (on ne l'éteint pas) et limite la propagation : $\mathcal{C}$: + $\mathcal{F}$: + $\mathcal{O}$: +. Éteindre brutalement contiendrait aussi, mais détruirait la mémoire : $\mathcal{C}$: + $\mathcal{F}$: - $\mathcal{O}$: -. On préfère isoler.

Application Responsable de la réponse à incident

Tenir l'ordre sous pression. Le RRI résiste à la pression de « tout rallumer tout de suite » : il fait tenir l'ordre confiner, figer, éradiquer, rétablir. C'est la discipline qui évite la rechute.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Préparer, qualifier, contenir, éradiquer, rétablir, apprendre.**
- **La gravité** fixe les délais.
- **La préparation** décide de la qualité de la réponse.
- **Éradiquer avant de rétablir**, sous peine de rechute.
- **Contenir en isolant**, pour préserver la preuve.

● Note

Points de contrôle de l'élève. Je sais : décrire le cycle ; classer par gravité ; expliquer le rôle de la préparation ; ordonner éradication et rétablissement ; articuler réponse et forensique.

✍ Exercice 15.1. Le cycle ★☆☆

Citez les six étapes du cycle de réponse.

✍ Exercice 15.2. Gravité ★☆☆

À quelle gravité classer un rançongiciel qui arrête la production ?

✍ Exercice 15.3. Ordre ★☆☆

Pourquoi ne pas rétablir avant d'éradiquer ?

✍ Exercice 15.4. Préparation ★★☆

Pourquoi la préparation est-elle la phase la plus déterminante ?

✍ Exercice 15.5. Isoler ★★☆

Pourquoi isoler plutôt qu'éteindre ? (Analyse CRO)

✍ Exercice 15.6. MAYO ★★☆

Reconstituez l'ordre des décisions de Mme NGASSA le 6 mars.

✍ Exercice 15.7. Figer ★★☆

Où insère-t-on la capture des preuves dans le cycle ?

✍ Exercice 15.8. Sauvegardes ★★☆

Pourquoi rétablir à partir de sauvegardes vérifiées hors ligne ?

✍ Exercice 15.9. Playbook ★★★

Rédigez le playbook rançongiciel de LiZbiZ, étape par étape, avec les décisions.

✍ Exercice 15.10. Grille ★★★

Construisez la grille de gravité de LiZbiZ avec délais, astreinte et escalades.

Note

Pour aller plus loin.

➢ ISO/IEC 27035 [11] ; NIST SP 800-61r2 [4].

Note

Transition. Répondre suppose une équipe organisée : le Chapitre 16 traite du CSIRT et du CERT.

16

LE CSIRT ET LE CERT

« En crise, ce qui n'est pas écrit n'a pas été décidé. »

Principe du cours

Niveau : *Fondamental* • Chapitre 15.

✦ Objectifs du chapitre

- ➢ Définir le CSIRT et le CERT, et leur différence.
- ➢ Décrire les rôles d'une cellule de réponse.
- ➢ Comprendre la main courante et la communication de crise.
- ➢ Situer la coopération avec l'ANTIC et les tiers.
- ➢ Dimensionner une cellule pour une PME.

Question directrice : qui décide, qui agit, qui parle pendant l'incident de LiZbiZ ?

Sans organisation, un incident se gère dans la confusion : tout le monde agit, personne ne décide, et rien n'est tracé. Ce chapitre présente la cellule de réponse, ses rôles, sa main courante et ses relations extérieures.

Plan du chapitre.

1. CSIRT et CERT (section 16.1).
2. Les rôles de la cellule (section 16.2).
3. La main courante (section 16.3).
4. Coopérer avec l'extérieur (section 16.4).

© *MaletYon*

16.1 CSIRT et CERT

Définition

CSIRT (*Computer Security Incident Response Team*) : équipe chargée de recevoir, analyser et traiter les incidents de sécurité d'un périmètre donné. **CERT** est une appellation voisine, protégée ; tout CERT est un CSIRT. L'ANTIC opère le CERT national camerounais.

16.2 Les Rôles de la Cellule

Rôle	Responsabilité
Responsable de la cellule	Décide, arbitre, rend compte à la direction
Analystes	Investiguent, contiennent, éradiquent
Référent technique métier	Connaît les systèmes atteints
Communication	Messages internes et externes, maîtrisés
Juridique	Obligations, signalements, ANTIC, assurance
Main courante	Consigne chaque décision et chaque action

Tableau 16.1. Les rôles d'une cellule de réponse

16.3 La Main Courante

Chaîne de custody

Tenir la main courante

1. Horodater chaque entrée.
2. Noter la décision, qui l'a prise, sur quelle base.
3. Noter l'action, qui l'a faite, son résultat.
4. Ne rien reconstruire après coup : on écrit sur le moment.
5. Conserver la main courante au dossier (preuve et RETEX).

Artefact · Main courante de l'opération MAYO

Nature : journal horodaté des décisions et actions du 6 mars. **Source :** tenue en direct par le secrétaire de cellule. **Pertinence :** établit qui a décidé quoi, et quand. **Fiabilité :** entrées horodatées, non modifiées. **Opposabilité :** preuve de la diligence de LiZbiZ.

16.4 Coopérer avec l'Extérieur

Scénario Opérationnel · Opération MAYO. La cellule de LiZbiZ

Constatation. LiZbiZ n'avait pas de CSIRT. Le 6 mars, une cellule est constituée en urgence : M. KOUNOU (technique), Mme NGASSA (responsable), NYONG SÉCURITÉ (analystes), un juriste, un chargé de communication. L'ANTIC est informée dans la journée.

Analyse (confiance élevée). L'improvisation a coûté du temps. Après l'incident, LiZbiZ formalise un CSIRT minimal et des playbooks : la prochaine cellule se réunira en minutes, pas en heures.

Application Responsable de la réponse à incident

Désigner avant la crise. Le responsable constitue la cellule et nomme les rôles à froid, avec suppléants et coordonnées. En crise, on active une liste, on ne cherche pas qui appeler.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **CSIRT** (générique) et **CERT** (appellation protégée) ; l'ANTIC opère le CERT national.
- **Les rôles** : responsable, analystes, métier, communication, juridique, main courante.
- **La main courante** trace décisions et actions, en direct.
- **On coopère** avec l'ANTIC et les tiers.
- **On désigne** la cellule avant la crise.

Note

Points de contrôle de l'élève. Je sais : distinguer CSIRT et CERT ; citer les rôles ; tenir une main courante ; situer la coopération ; dimensionner une cellule.

Exercice 16.1. CSIRT ou CERT ★☆☆

Quelle est la différence entre CSIRT et CERT ?

Exercice 16.2. Rôles ★☆☆

Citez quatre rôles d'une cellule de réponse.

✍ Exercice 16.3. Main courante ★☆☆

Que consigne-t-on dans une main courante ?

✍ Exercice 16.4. Écrit ★★☆

Pourquoi « ce qui n'est pas écrit n'a pas été décidé » ?

✍ Exercice 16.5. ANTIC ★★☆

Quand et pourquoi informer l'ANTIC ?

✍ Exercice 16.6. MAYO ★★☆

Qu'a coûté à LiZbiZ l'absence de CSIRT préétabli ?

✍ Exercice 16.7. Communication ★★☆

Pourquoi un rôle communication dédié dans la cellule ?

✍ Exercice 16.8. Opposabilité ★★☆

En quoi la main courante est-elle une preuve de diligence ?

✍ Exercice 16.9. Charte de CSIRT ★★★

Rédigez la charte du CSIRT minimal de LiZbiZ : périmètre, rôles, suppléants, coordonnées.

✍ Exercice 16.10. Modèle de main courante ★★★

Concevez le modèle de main courante de LiZbiZ.

● Note

Pour aller plus loin.

➢ ISO/IEC 27035 [11] ; NIST SP 800-61r2 [4].

● Note

Transition. Pour anticiper, la cellule s'appuie sur le renseignement sur la menace : le Chapitre 17 le traite.

17

LE RENSEIGNEMENT SUR LA MENACE

« Connaître l'adversaire, c'est transformer une alerte en histoire. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 16 ; Chapitre 7.

✦ Objectifs du chapitre

- ➢ Définir le renseignement sur la menace et ses usages.
- ➢ Utiliser la chaîne d'attaque (Kill Chain) et ATT&CK.
- ➢ Comprendre le modèle du Diamant.
- ➢ Situer les formats d'échange (STIX/TAXII) et les indicateurs.
- ➢ Mapper un incident aux techniques de l'adversaire.

Question directrice : l'attaque de LiZbiZ ressemble-t-elle à d'autres, et qu'en déduire ?

Une attaque n'est presque jamais inédite : elle suit des étapes connues et emploie des techniques répertoriées. Le renseignement sur la menace permet de reconnaître le mode opératoire, d'anticiper la suite et d'écrire de meilleures règles.

Plan du chapitre.

1. Qu'est-ce que le renseignement (section 17.1).
2. Chaîne d'attaque et ATT&CK (section 17.2).
3. Le modèle du Diamant (section 17.3).
4. Échanger le renseignement (section 17.4).

© *MaletYon*

17.1 Qu'est-ce que le Renseignement

Définition

Renseignement sur la menace : information analysée sur les adversaires, leurs motivations, leurs techniques et leurs indicateurs, qui éclaire la détection, la réponse et la décision. Il transforme des données brutes en connaissance actionnable.

17.2 Chaîne d'Attaque et ATT&CK

La **chaîne d'attaque** (Lockheed Martin, 2011) décrit une intrusion en étapes : reconnaissance, armement, livraison, exploitation, installation, pilotage, actions sur objectif. **MITRE ATT&CK** affine en tactiques et techniques observées. Les deux se complètent : la chaîne raconte l'histoire, ATT&CK en nomme les gestes.

Étape (GAROUA)	Tactique ATT&CK	Trace
Accès initial (compte de service)	Accès aux identifiants	Connexion anormale
Installation (WinUpd32)	Persistance	Service installé
Pilotage (connexions régulières)	Commande et contrôle	Flux réguliers
Exfiltration (40 Go)	Exfiltration	Volume sortant
Chiffrement	Impact	Fichiers chiffrés

Tableau 17.1. L'opération GAROUA mappée à ATT&CK [6], [18]

17.3 Le Modèle du Diamant

Définition

Modèle du Diamant (2013) : cadre d'analyse d'une intrusion par quatre sommets reliés : l'*adversaire*, ses *capacités*, son *infrastructure*, et la *victime*. Relier deux sommets connus permet d'inférer les autres.

Exemple : connaissant l'infrastructure de pilotage (l'adresse externe) et la victime (LiZbiZ), on peut rapprocher l'incident d'autres victimes partageant la même infrastructure, et ainsi caractériser l'adversaire.

17.4 Échanger le Renseignement

Les **indicateurs de compromission** (adresses, condensats, noms de domaine) s'échangent entre organisations dans des formats normalisés (**STIX** pour décrire, **TAXII** pour transporter). L'ANTIC et les CERT sectoriels jouent ce rôle de partage au niveau national.

★ Attention

Prudence. Un indicateur partagé peut vieillir ou être faux.

Règle : on qualifie la source et la fraîcheur d'un indicateur avant d'en faire une règle de blocage : un indicateur périmé génère du bruit, un indicateur erroné bloque du trafic légitime.

Scénario Opérationnel · Opération MAYO. Le mode opératoire reconnu

Constatation. Mappée à ATT&CK et au Diamant, l'attaque de LiZbiZ correspond à un mode opératoire de rançongiciel courant en Afrique centrale : accès par compte de service, persistance par service, exfiltration avant chiffrement.

Analyse (confiance moyenne). La reconnaissance du mode opératoire a permis d'anticiper la recherche de persistances cachées et d'écrire des règles ciblées. On ne nomme pas l'adversaire avec certitude : NEK sur l'attribution.

Application Analyste SOC / Red Team

Du renseignement aux règles. L'analyste transforme chaque caractérisation d'adversaire en règles de détection et en points de chasse : le renseignement ne vaut que s'il améliore la défense.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le renseignement** rend la menace actionnable.
- **La chaîne d'attaque** raconte, **ATT&CK** nomme les gestes.
- **Le Diamant** relie adversaire, capacités, infrastructure, victime.
- **STIX/TAXII** échangent les indicateurs ; on qualifie leur fraîcheur.
- **L'attribution** reste souvent un NEK.

Note

Points de contrôle de l'élève. Je sais : définir le renseignement ; mapper une attaque à la chaîne et à ATT&CK ; appliquer le Diamant ; situer STIX/TAXII ; transformer le renseignement en règles.

✍ Exercice 17.1. Chaîne ★☆☆

Citez trois étapes de la chaîne d'attaque.

✍ Exercice 17.2. Diamant ★☆☆

Quels sont les quatre sommets du modèle du Diamant ?

✍ Exercice 17.3. Indicateur ★☆☆

Donnez trois exemples d'indicateurs de compromission.

✍ Exercice 17.4. Mapper ★★☆

Mappez l'installation de `WinUpd32` à une tactique ATT&CK.

✍ Exercice 17.5. Inférer ★★☆

Connaissant l'infrastructure et la victime, qu'infère-t-on avec le Diamant ?

✍ Exercice 17.6. Indicateur périmé ★★☆

Pourquoi qualifier la fraîcheur d'un indicateur avant d'en faire une règle ?

✍ Exercice 17.7. Attribution ★★☆

Pourquoi l'attribution reste-t-elle souvent un NEK ?

✍ Exercice 17.8. STIX/TAXII ★★☆

Quelle est la différence entre STIX et TAXII ?

✍ Exercice 17.9. Mapping complet ★★★

Dressez le mapping complet de l'opération GAROUA à ATT&CK.

✍ Exercice 17.10. Du renseignement aux règles ★★★

À partir du mode opératoire reconnu, proposez trois règles et deux points de chasse.

● Note

Pour aller plus loin.

➢ MITRE ATT&CK [18] ; chaîne d'attaque [6] ; modèle du Diamant [2] ; STIX/TAXII [17].

Note

Transition. Reste à agir concrètement sur l'incident : le Chapitre 18 traite du confinement, de l'éradication et du rétablissement.

18

CONFINEMENT, ÉRADICATION, RÉTABLISSEMENT

« Contenir sans détruire la preuve, éradiquer sans oublier une porte,
rétablir sans ramener l'attaquant. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 15.

✦ Objectifs du chapitre

- ➢ Choisir une stratégie de confinement adaptée.
- ➢ Éradiquer complètement la présence de l'attaquant.
- ➢ Rétablir à partir de sauvegardes sûres.
- ➢ Vérifier qu'il n'y a pas de rechute.
- ➢ Décider, ou non, de payer une rançon.

Question directrice : comment remettre LiZbiZ en marche sans rouvrir la porte ?

Après la qualification et la capture des preuves, il faut agir : contenir, éradiquer, rétablir. Chaque étape a ses pièges. Ce chapitre les parcourt, et aborde la question difficile du paiement de la rançon.

Plan du chapitre.

1. Le confinement (section 18.1).
2. L'éradication (section 18.2).
3. Le rétablissement (section 18.3).
4. Faut-il payer ? (section 18.4).

© MaletYon

18.1 Le Confinement

Stratégie	Principe	Quand
Isolement réseau	Couper la machine du réseau sans l'éteindre	Préserve la preuve
Segmentation	Fermer un segment	Limiter la propagation
Blocage de comptes	Désactiver les comptes compromis	Couper l'accès
Arrêt (dernier recours)	Éteindre	Si la propagation l'exige

Tableau 18.1. Stratégies de confinement

On privilégie l'isolement réseau, qui préserve la mémoire et la preuve (Chapitre 13).

18.2 L'Éradication

Chaîne de custody

Éradiquer

1. Supprimer les accès de l'attaquant (comptes créés, clés déposées).
2. Supprimer les persistances (services, tâches, clés de démarrage).
3. Corriger la faille d'entrée (sinon l'attaquant revient).
4. Changer les secrets exposés (mots de passe, clés).
5. Vérifier l'éradication avant de rétablir.

★ Attention

Erreur fréquente. Supprimer le rançongiciel visible et croire la machine propre.

Règle : l'attaquant a souvent plusieurs portes (comptes, services, accès distant). On éradique à partir de la chronologie forensique, qui liste *toutes* ses traces, pas seulement la charge finale.

18.3 Le Rétablissement

On rétablit à partir de sauvegardes **vérifiées** et **hors ligne** (une sauvegarde en ligne a pu être chiffrée elle aussi). On restaure par étapes, en surveillant étroitement, prêt à reconfiner en cas de rechute. La supervision renforcée (Partie II) accompagne le retour à la normale.

18.4 Faut-il Payer ?

Scénario Opérationnel · Opération MAYO. LiZbiZ ne paie pas

Constatation. La rançon demandée s'élève à 25 millions de FCFA. LiZbiZ dispose de sauvegardes hors ligne du serveur de suivi, vieilles de cinq jours. Les données exfiltrées, elles, sont déjà perdues.

Analyse (confiance élevée). Payer ne garantit ni la restitution ni la non-divulgation, finance le crime, et peut être juridiquement risqué. LiZbiZ choisit de ne pas payer : elle restaure depuis les sauvegardes (perte de cinq jours de données de suivi, reconstituées), notifie l'ANTIC et les clients concernés par l'exfiltration. La décision est documentée.

Γ_{CRO} Analyse CRO · Confidentialité · Fiabilité · Opposabilité

La décision de payer, sous l'angle CRO. Payer n'améliore pas la $\mathcal{C}$: - $\mathcal{F}$: - $\mathcal{O}$: - : les données exfiltrées restent exposées (C), rien ne garantit l'intégrité des données « rendues » (F), et le paiement affaiblit la position devant l'autorité (O). La préparation (sauvegardes) est la vraie réponse.

Application Responsable de la réponse à incident et RSSI

La meilleure réponse au rançongiciel est antérieure à l'attaque. Des sauvegardes hors ligne testées rendent la question du paiement presque théorique. Le RRI prépare cette réponse à froid.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Confiner** en isolant, pour préserver la preuve.
- **Éradiquer** toutes les portes, pas seulement la charge visible.
- **Corriger la faille d'entrée** avant de rétablir.
- **Rétablir** depuis des sauvegardes vérifiées hors ligne.
- **Payer** n'est pas une solution ; la préparation l'est.

Note

Points de contrôle de l'élève. Je sais : choisir une stratégie de confinement ; éradiquer complètement ; rétablir sûrement ; vérifier l'absence de rechute ; argumenter sur le paiement.

✍ Exercice 18.1. Confiner ★☆☆

Pourquoi préférer l'isolement réseau à l'extinction ?

✍ Exercice 18.2. Portes ★☆☆

Citez trois « portes » qu'un attaquant peut laisser.

✍ Exercice 18.3. Sauvegardes ★☆☆

Pourquoi rétablir depuis des sauvegardes hors ligne ?

✍ Exercice 18.4. Éradication incomplète ★★☆

Pourquoi supprimer seulement le rançongiciel visible ne suffit-il pas ?

✍ Exercice 18.5. Faille d'entrée ★★☆

Que se passe-t-il si l'on rétablit sans corriger la faille d'entrée ?

✍ Exercice 18.6. Payer ★★☆

Donnez trois raisons de ne pas payer une rançon.

✍ Exercice 18.7. CRO ★★☆

Analysez la décision de payer sous l'angle CRO.

✍ Exercice 18.8. MAYO ★★☆

Reconstituez la décision de LiZbiZ : pourquoi ne pas payer, et comment rétablir ?

✍ Exercice 18.9. Plan de rétablissement ★★★

Rédigez le plan de rétablissement de LiZbiZ après l'éradication.

✍ Exercice 18.10. Politique rançongiciel ★★★

Rédigez la politique de LiZbiZ sur le paiement des rançons, fondée sur la préparation.

● Note

Pour aller plus loin.

➢ ISO/IEC 27035 [11] ; NIST SP 800-61r2 [4].

● Note

Transition. L'incident traité, il reste à en tirer les leçons : la Partie VI s'ouvre sur le retour d'expérience (Chapitre 19).

partie VI

Apprendre et Mesurer

© MaletYon

19

RETOUR D'EXPÉRIENCE ET AMÉLIORATION CONTINUE

« Un incident dont on ne tire pas de leçon
est un incident que l'on paiera deux fois. »

Principe du cours

Niveau : *Fondamental* • Partie V.

✦ Objectifs du chapitre

- ➢ Conduire un retour d'expérience utile et sans procès.
- ➢ Distinguer causes immédiates et causes profondes.
- ➢ Transformer les leçons en actions suivies.
- ➢ Comprendre la culture juste.
- ➢ Boucler sur la supervision et la détection.

Question directrice : qu'a appris LiZbiZ, et comment éviter que cela se reproduise ?

Une fois le service rétabli, la tentation est de tourner la page. C'est l'erreur : la phase d'enseignements de l'ISO 27035 est celle qui fait progresser. Ce chapitre conduit le RETEX et le transforme en actions.

Plan du chapitre.

1. Conduire un RETEX (section 19.1).
2. Causes immédiates et profondes (section 19.2).
3. Des leçons aux actions (section 19.3).
4. La culture juste (section 19.4).

© *MaletYon*

19.1 Conduire un RETEX

Chaîne de custody

Conduire un retour d'expérience

1. Réunir les acteurs dans les 72 heures, à partir de la main courante.
2. Reconstituer la chronologie des faits (pas des responsabilités).
3. Identifier ce qui a bien et mal fonctionné.
4. Remonter aux causes profondes, au-delà du symptôme.
5. Décider des actions, avec responsable et échéance.

19.2 Causes Immédiates et Profondes

Niveau	Exemple (GAROUA)
Cause immédiate	Un compte de service à mot de passe faible compromis
Cause intermédiaire	Pas de supervision, journaux non lus
Cause profonde	Absence de fonction de détection et de gouvernance de la sécurité

Tableau 19.1. Remonter aux causes profondes

★ Attention

Erreur fréquente. S'arrêter à la cause immédiate (« le mot de passe était faible ») et sanctionner.

Règle : corriger la seule cause immédiate laisse la cause profonde intacte ; l'incident reviendra sous une autre forme. On traite les trois niveaux.

19.3 Des Leçons aux Actions

Scénario Opérationnel · Opération MAYO. Le plan d'action

Constatation. Le RETEX de LiZbiZ débouche sur : mettre en place une supervision (SOC hybride), journaliser `FS-01`, durcir les comptes de service, sauvegarder hors ligne, écrire des playbooks, former le personnel. Chaque action a un responsable et une échéance.

Analyse (confiance élevée). Les actions traitent les trois niveaux de causes. Le RETEX n'est utile que si ses actions sont suivies : LiZbiZ les inscrit dans un plan revu chaque trimestre.

19.4 La Culture Juste

Définition

Culture juste : culture où l'on signale les erreurs et les quasi-incidents sans crainte de sanction injuste. Elle distingue l'erreur honnête (que l'on analyse) de la faute délibérée (que l'on sanctionne). Sans elle, les incidents se cachent et ne s'apprennent pas.

Application RSSI

Protéger ceux qui signalent. Le RSSI fait du RETEX un espace sans procès : le technicien qui a redémarré `FS-01` de bonne foi n'est pas sanctionné, il devient l'exemple qui fonde la consigne de première intervention. On apprend des erreurs, on ne les enterre pas.

À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le RETEX** se conduit à partir de la main courante, sans procès.
- **Trois niveaux de causes** : immédiate, intermédiaire, profonde.
- **On traite les trois**, sinon l'incident revient.
- **Des actions suivies**, avec responsable et échéance.
- **La culture juste** fait remonter ce qu'il faut apprendre.

Note

Points de contrôle de l'élève. Je sais : conduire un RETEX ; distinguer les niveaux de causes ; transformer les leçons en actions ; expliquer la culture juste ; boucler sur la supervision.

Exercice 19.1. Délai ★☆☆

Dans quel délai conduire le RETEX ? À partir de quel document ?

Exercice 19.2. Causes ★☆☆

Distinguez cause immédiate et cause profonde dans GAROUA.

Exercice 19.3. Culture juste ★☆☆

Qu'est-ce que la culture juste ?

✍ **Exercice 19.4. Symptôme ★★☆**

Pourquoi corriger la seule cause immédiate ne suffit-il pas ?

✍ **Exercice 19.5. Actions ★★☆**

Reliez chaque action du plan de MAYO à un niveau de cause.

✍ **Exercice 19.6. Sans procès ★★☆**

Pourquoi le RETEX ne doit-il pas être un procès ?

✍ **Exercice 19.7. Le technicien ★★☆**

Comment traiter le cas du technicien qui a redémarré `FS-01` ?

✍ **Exercice 19.8. Suivi ★★☆**

Comment s'assurer que les actions du RETEX sont réellement suivies ?

✍ **Exercice 19.9. Compte rendu de RETEX ★★★**

Rédigez le compte rendu de RETEX de l'opération GAROUA.

✍ **Exercice 19.10. Plan d'amélioration ★★★**

Construisez le plan d'amélioration trimestriel de LiZbiZ issu du RETEX.

● **Note**

Pour aller plus loin.

➢ ISO/IEC 27035 [11].

● **Note**

Transition. Reste à mesurer tout cela : le Chapitre 20 clôt le cours sur la mesure et la recherche.

20

MESURER LA SUPERVISION ET LA RÉPONSE

« Mesurer la sécurité, c'est aussi savoir dire ce que l'on ignore. »

Principe du cours

Niveau : *Avancé* • L'ensemble du cours ; notions d'auditologie.

✦ Objectifs du chapitre

- ➢ Choisir des indicateurs de supervision et de réponse honnêtes.
- ➢ Appliquer le verdict à trois valeurs OUI, NON, NEK.
- ➢ Éviter les indicateurs trompeurs.
- ➢ Inscrire la supervision dans un cycle d'amélioration.
- ➢ Ouvrir sur la recherche en détection et réponse.

Question directrice : LiZbiZ est-elle « prête » pour le prochain incident ?

Six mois après, la question revient : « Sommes-nous prêts ? » La réponse honnête n'est ni oui ni non en bloc, mais un ensemble de verdicts précis, et, pour ce qui n'a pu être éprouvé, un franc NEK. Ce chapitre clôt le cours sur la mesure.

Plan du chapitre.

1. Des indicateurs honnêtes (section 20.1).
2. Le verdict à trois valeurs (section 20.2).
3. Les indicateurs trompeurs (section 20.3).
4. Le cycle et la recherche (section 20.4).

© *MaletYon*

20.1 Des Indicateurs Honnêtes

Indicateur	Ce qu'il dit
Délai de détection, de réaction	Rapidité à voir et à contenir
Couverture de journalisation	Part du parc réellement surveillé
Couverture de détection (ATT&CK)	Part des techniques que l'on verrait
Taux de réussite des exercices	Préparation de la cellule
Taux de correction des actions RETEX	Capacité à apprendre

Tableau 20.1. Indicateurs de supervision et de réponse [8]

20.2 Le Verdict à Trois Valeurs

■ Définition

Verdict à trois valeurs : à chaque question de préparation, la réponse est OUI (démontré, avec preuve), NON (réfuté, avec preuve) ou NEK (indéterminé : les preuves manquent pour trancher). Le NEK n'est pas un aveu de faiblesse : c'est une exigence d'honnêteté qui désigne où porter l'effort.

Verdict	Question	Exemple (LiZbiZ)
OUI	Détecte-t-on un compte de service anormal ?	Règle écrite et éprouvée
NON	Détecte-t-on l'exfiltration depuis tout serveur ?	FS-01 journalisé, pas les autres
NEK	Résisterait-on à un attaquant plus patient ?	Jamais éprouvé par un exercice

Tableau 20.2. Le verdict OUI / NON / NEK appliqué [16]

★ Attention

Violation typique. Conclure OUI (« nous sommes prêts ») faute d'avoir éprouvé.

Règle : ce qui n'a pas été testé par un exercice reste NEK, pas OUI. L'absence d'incident n'est pas une preuve de préparation.

20.3 Les Indicateurs Trompeurs

Indicateur trompeur	Pourquoi il trompe
Nombre d'alertes	Dépend des règles, pas du risque
« Aucun incident ce mois-ci »	Peut signifier « rien détecté »
Nombre d'outils déployés	L'outil n'est pas la détection
Temps passé au SOC	Mesure l'effort, pas le résultat

Tableau 20.3. Indicateurs à manier avec prudence

20.4 Le Cycle et la Recherche

La supervision s'inscrit dans un cycle : détecter, répondre, apprendre, améliorer la détection, éprouver par des exercices, repartir des NEK. La recherche prolonge ce cycle : mesure de la couverture de détection, automatisation de la réponse, renseignement adapté au contexte d'Afrique centrale, et application du cadre de l'auditologie à la réduction de l'incertitude en supervision.

Scénario Opérationnel · Opération MBAM. L'exercice qui lève des NEK

Constatation. Pour éprouver sa préparation, LiZbiZ participe à un exercice d'équipe (type équipe violette) avec NYONG SÉCURITÉ : 30 techniques jouées, 18 détectées. Les 12 non détectées étaient des NEK : on ne savait pas si on les verrait. Désormais, on sait que non, et on écrit les règles.

Analyse (confiance élevée). L'exercice transforme des NEK en OUI ou en NON étayés. C'est le seul moyen honnête de répondre « sommes-nous prêts ? ».

Application RSSI, analyste SOC, analyste forensique

Dire le vrai, NEK compris. Le professionnel ne cède pas au OUI rassurant : il distingue ce qu'il a démontré, réfuté, et ce qu'il n'a pu trancher. C'est à ce triple langage qu'on reconnaît un bilan honnête.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Des indicateurs** de délai, couverture, exercices, correction.
- **OUI, NON, NEK** : le verdict honnête.
- **L'absence d'incident** n'est pas une preuve de préparation.
- **Les indicateurs d'activité** trompent.

➢ **Les exercices** transforment les NEK en verdicts étayés.

Note

Points de contrôle de l'élève. Je sais : choisir des indicateurs honnêtes ; appliquer OUI/NON/NEK ; reconnaître un indicateur trompeur ; décrire le cycle ; situer les pistes de recherche.

✍ Exercice 20.1. Indicateurs ★☆☆

Citez trois indicateurs honnêtes de supervision.

✍ Exercice 20.2. Trois valeurs ★☆☆

Donnez le sens de OUI, NON et NEK.

✍ Exercice 20.3. Trompeur ★☆☆

Pourquoi « aucun incident ce mois-ci » peut-il tromper ?

✍ Exercice 20.4. Classer ★★☆

Attribuez OUI, NON ou NEK : détection d'un compte de service anormal ; résistance à un attaquant patient ; détection de l'exfiltration partout.

✍ Exercice 20.5. Pas de test ★★☆

Pourquoi ce qui n'a pas été éprouvé reste-t-il NEK ?

✍ Exercice 20.6. MBAM ★★☆

Comment l'exercice MBAM transforme-t-il des NEK en verdicts étayés ?

✍ Exercice 20.7. Note au DG ★★☆

Répondez à « sommes-nous prêts ? » en OUI / NON / NEK pour LiZbiZ.

✍ Exercice 20.8. Outils ★★☆

Pourquoi le nombre d'outils déployés n'est-il pas un bon indicateur ?

✍ Exercice 20.9. Tableau de bord ★★★

Construisez le tableau de bord annuel de supervision et de réponse de LiZbiZ, NEK compris.

✍ Exercice 20.10. Question de recherche ★★★

Formulez une question de recherche sur la mesure de la couverture de détection en contexte d'Afrique centrale.

● Note

Pour aller plus loin.

➢ ISO/IEC 27004 [8] ; cadre de l'auditologie [16].

● Note

Fin du cours. De l'écran de rançon au verdict mesuré, SIS589 aura montré qu'une attaque se voit venir, s'investigue proprement et se maîtrise : superviser, investiguer, répondre, apprendre, mesurer, sans jamais confondre ce que l'on constate et ce que l'on en déduit.

A

GLOSSAIRE

Ce glossaire reprend les notions définies dans les chapitres. Le renvoi indique le chapitre où la notion est présentée.

Admissibilité Aptitude d'une preuve à être reçue par un tiers, selon la manière dont elle a été recueillie et documentée (Ch. 10).

Analyse forensique Recherche méthodique, documentée et opposable des traces d'un événement (Ch. 11).

ANTIC Agence Nationale des Technologies de l'Information et de la Communication, autorité camerounaise de la sécurité électronique (Ch. 9).

Canal de pilotage Connexions régulières de faible volume par lesquelles un attaquant commande un code malveillant (Ch. 14).

CERT Appellation protégée d'un CSIRT ; l'ANTIC opère le CERT national (Ch. 16).

Chaîne d'attaque Description d'une intrusion en étapes, de la reconnaissance à l'action sur objectif (Ch. 17).

Chaîne de custody Continuité documentée de la détention d'une preuve (Ch. 11).

Chasse Recherche proactive de ce qui n'a pas déclenché d'alerte (Ch. 2).

Condensat Empreinte numérique qui prouve l'intégrité d'une copie (Ch. 11).

Corréler Rapprocher automatiquement des événements de sources différentes pour faire émerger une alerte (Ch. 5).

CSIRT Équipe de réponse aux incidents de sécurité d'un périmètre (Ch. 16).

Culture juste Culture où l'on signale les erreurs sans crainte de sanction injuste (Ch. 19).

Délai de présence Durée entre la première compromission et sa détection (Ch. 1).

Exfiltration Transfert sortant anormal de données vers une destination contrôlée par l'attaquant (Ch. 14).

Faux négatif Comportement visé qu'une règle laisse passer (Ch. 7).

Faux positif Alerte sans incident réel (Ch. 7).

Indicateur de compromission Élément observable (adresse, condensat, domaine) trahissant une attaque (Ch. 17).

Ingénierie de détection Écriture et maintenance des règles de détection (Ch. 7).

ISO/IEC 27035 Norme de gestion des incidents de sécurité, cycle en cinq phases (Ch. 8).

ISO/IEC 27037 Lignes directrices de collecte et de préservation de la preuve numérique (Ch. 8).

MITRE ATT&CK Base de connaissances des tactiques et techniques des attaquants (Ch. 17).

Modèle du Diamant Cadre d'analyse d'une intrusion : adversaire, capacités, infrastructure, victime (Ch. 17).

NIST SP 800-86 Guide d'intégration de la forensique à la réponse : collecte, examen, analyse, rapport (Ch. 8).

Ordre de volatilité Ordre d'acquisition des preuves, du plus fugace au plus stable (Ch. 11).

RFC 3227 Lignes directrices de collecte et d'archivage des preuves (Ch. 8).

SIEM Plateforme de collecte, corrélation et alerte sur les journaux (Ch. 5).

SOC Centre d'opérations de sécurité : détecter, analyser, traiter en continu (Ch. 2).

STIX / TAXII Formats d'échange du renseignement sur la menace (Ch. 17).

Supervision de sécurité Collecte et analyse continues des traces pour détecter les attaques (Ch. 1).

Trilemme CRO Confidentialité, Fiabilité, Opposabilité : les trois dimensions de toute trace et de tout acte d'enquête (Ch. 0).

Verdict à trois valeurs OUI (démontré), NON (réfuté), NEK (indéterminé) (Ch. 20).

Vrai positif Alerte sur un comportement réellement visé (Ch. 7).

B

RÉFÉRENTIEL DES OUTILS

Les outils cités sont des exemples. Le cours insiste sur la méthode : l'outil sert la lecture, il ne la remplace pas. Tout usage se fait dans un cadre autorisé ou en laboratoire fermé.

Catégorie d'outil	Usage	Chapitre, lab
Collecte de journaux	Centraliser, normaliser, horodater	Ch. 4, SAFI-LAB-02
SIEM	Corréler, alerter, cas d'usage	Ch. 5, SAFI-LAB-03
Sondes IDS/IPS	Détecter réseau et hôte	Ch. 6
Acquisition forensique	Copie bit à bit, condensat	Ch. 11, SAFI-LAB-05
Analyse système	Artefacts, chronologie	Ch. 12, SAFI-LAB-06
Acquisition mémoire	Capture de la mémoire vive	Ch. 13
Analyse de flux	Journaux de flux exportés	Ch. 14, SAFI-LAB-07
Référentiel ATT&CK	Planifier, mapper, mesurer	Ch. 17, SAFI-LAB-09
Tableur	Chronologie, tableau de bord, couverture	Ch. 3, SAFI-LAB-10

★ Attention

Rappel. Aucun de ces outils ne se dirige vers un système réel sans autorisation. L'entraînement se fait en laboratoire fermé.

© MaletYon

C

MODÈLES ET PROCÉDURES

Consigne de première intervention

1. Ne pas éteindre, ne pas redémarrer, ne pas « nettoyer ».
2. Isoler la machine du réseau (sans l'éteindre).
3. Prévenir le responsable de la réponse à incident.
4. Noter l'heure et ce qui a été constaté.
5. Attendre la capture des preuves avant toute action.

Fiche de constat

Rubrique	Contenu
Identifiant	T-xx, titre court
Constatation	Le fait vérifiable
Preuve	Artefact, condensat, source
Analyse	Interprétation, niveau de confiance
Gravité	Cotation justifiée
Recommandation	Correction concrète

Fiche de chaîne de custody

Rubrique	Contenu
Pièce	Numéro, description, condensat
Acquisition	Qui, quand, comment, outil
Transferts	De qui à qui, quand, pourquoi
Conservation	Lieu, protection

Plan du rapport d'incident

1. Synthèse pour la direction.
2. Chronologie des faits.
3. Analyse (constatation / interprétation).
4. Impact et obligations (ANTIC, données).

© *MaletYon*

5. Actions : confinement, éradication, rétablissement.
6. Retour d'expérience et recommandations.

D

TEXTES JURIDIQUES ET NORMATIFS

Seuls les éléments vérifiés dans le texte officiel sont cités dans les chapitres. Ce tableau indique où les trouver.

Droit camerounais et africain

Texte	Objet	Chapitre
Loi n° 2010/012 du 21 déc. 2010	Cybersécurité et cybercriminalité	9
Loi n° 2010/013 du 21 déc. 2010	Communications électroniques	9
Loi n° 2024/017 du 23 déc. 2024	Protection des données personnelles	9
Convention de Malabo (UA, 2014)	Cybersécurité et données, Afrique	9
Convention de Budapest (2001)	Cybercriminalité, preuve, coopération	9

Normes et guides internationaux

Référence	Objet	Chapitre
ISO/IEC 27035	Gestion des incidents	8
ISO/IEC 27037	Preuve numérique	8
ISO/IEC 27004	Mesure de la sécurité	3
NIST SP 800-86	Forensique et réponse	8
NIST SP 800-61 Rev. 2	Traitement des incidents	15
RFC 3227	Collecte et archivage des preuves	8
MITRE ATT&CK	Tactiques et techniques	17
CIS Controls v8	Mesures de sécurité prioritaires	2

© *MaletYon*

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures. Les références complètes figurent dans la bibliographie du livre.

Parties I et II · Superviser, collecter, détecter

- NIST SP 800-61r2 [4] : le traitement des incidents.
- CIS Controls v8 [3] : la place de la supervision.
- MITRE ATT&CK [18] : le vocabulaire des techniques.

Partie III · Cadre normatif et juridique

- ISO/IEC 27035 [11] et 27037 [7] : incident et preuve.
- NIST SP 800-86 [12], RFC 3227 [1] : forensique et volatilité.
- Lois 2010/012 [13], 2024/017 [15] ; Malabo [19] ; Budapest [5].

Partie IV · L'analyse forensique

- NIST SP 800-86 [12] : la démarche forensique.
- ISO/IEC 27037 [7] : la préservation.

Partie V · La réponse à incident

- ISO/IEC 27035 [11] : le cycle de réponse.
- Chaîne d'attaque [6], Diamant [2], STIX/TAXII [17].

Partie VI · Apprendre et mesurer

- ISO/IEC 27004 [8] : la mesure.
- T. E. Minka Mi Nguidjoï [16] : le verdict à trois valeurs.

F

CONTACTS ET RESSOURCES

Les adresses sont celles des sites institutionnels à la date de rédaction ; à vérifier.

Organisation	Rôle	Site
ANTIC	Sécurité électronique, CERT national (Cameroun)	`www.antic.cm`
MINPOSTEL	Tutelle des communications électroniques	`www.minpostel.gov.cm`
Union africaine	Convention de Malabo	`au.int`
Conseil de l'Europe	Convention de Budapest	`coe.int`
MITRE	ATT&CK	`attack.mitre.org`
NIST	Publications SP 800	`www.nist.gov`
ISO	Normes ISO et ISO/IEC	`www.iso.org`

Note

La plateforme du cours. Les fiches d'auto-évaluation et les dix labs de NDAP SUKULU pour ce cours sont accessibles par le code `SIS589`.

© *MaletYon*

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] D. Brezinski et T. Killalea, « Guidelines for Evidence Collection and Archiving, » Internet Engineering Task Force, RFC 3227, 2002.

[2] S. Caltagirone, A. Pendergast et C. Betz, « The Diamond Model of Intrusion Analysis, » Center for Cyber Intelligence Analysis et Threat Research, rapp. tech., 2013.

[3] Center for Internet Security, *CIS Critical Security Controls, Version 8*, Center for Internet Security, East Greenbush, NY, 2021.

[4] P. Cichonski, T. Millar, T. Grance et K. Scarfone, « Computer Security Incident Handling Guide, » National Institute of Standards et Technology, NIST Special Publication 800-61 Rev. 2, 2012.

[5] Conseil de l'Europe, *Convention sur la cybercriminalité (Convention de Budapest, STE n° 185)*, Conseil de l'Europe, Budapest, 2001.

[6] E. M. Hutchins, M. J. Cloppert et R. M. Amin, « Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains, » Lockheed Martin Corporation, rapp. tech., 2011.

[7] ISO/IEC, *ISO/IEC 27037:2012 · Guidelines for identification, collection, acquisition and preservation of digital evidence*, International Organization for Standardization, Genève, 2012.

[8] ISO/IEC, *ISO/IEC 27004:2016 · Information security management · Monitoring, measurement, analysis and evaluation*, International Organization for Standardization, Genève, 2016.

[9] ISO/IEC, *ISO/IEC 27001:2022 · Information security, cybersecurity and privacy protection · Information security management systems · Requirements*, International Organization for Standardization, Genève, 2022.

[10] ISO/IEC, *ISO/IEC 27002:2022 · Information security controls*, International Organization for Standardization, Genève, 2022.

[11] ISO/IEC, *ISO/IEC 27035 · Information technology · Information security incident management*, International Organization for Standardization, Genève, 2023.

[12] K. Kent, S. Chevalier, T. Grance et H. Dang, « Guide to Integrating Forensic Techniques into Incident Response, » National Institute of Standards et Technology, NIST Special Publication 800-86, 2006.

[13] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun*, 21 déc. 2010.

[14] *Loi n° 2010/013 du 21 décembre 2010 régissant les communications électroniques au Cameroun*, 21 déc. 2010.

[15] *Loi n° 2024/017 du 23 décembre 2024 régissant la protection des données à caractère personnel au Cameroun*, 23 déc. 2024.

[16] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. (22 juill. 2026), adresse : https://hal.science/hal-05701007.

[17] OASIS, *STIX and TAXII : Structured Threat Information Expression and Trusted Automated Exchange of Intelligence Information*, OASIS Open, 2021.

[18] The MITRE Corporation, *MITRE ATT&CK : Adversarial Tactics, Techniques, and Common Knowledge*, https://attack.mitre.org/, Consulté en 2026, 2024.

[19] Union africaine, *Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel (Convention de Malabo)*, Union africaine, Malabo, 2014.

INDEX

Admissibilité, 56
Analyse forensique, 62
ANTIC, 52

canal de pilotage, 76
Cas d'usage de détection, 30
CERT, 88
chasse, 14
chaîne d'attaque, 92
condensat, 62
Confidentialité, 5
copie bit à bit, 62
Corréler, 30
CSIRT, 88
Culture juste, 105

délai de détection, 18
Délai de présence, 10
délai de réaction, 18
détection, 10

exfiltration, 76

Faux négatif, 40
Faux positif, 40
Fiabilité, 5
fiabilité, 46

Gouvernance de la supervision, 18

horodatés, 24
hors ligne, 98

indicateurs de compromission, 92
ingénierie de détection, 14
ISO/IEC 27035, 46
ISO/IEC 27037, 46

MITRE ATT&CK, 92
Modèle du Diamant, 92

NIST SP 800-86, 46
normalisés, 24

Opposabilité, 5
ordre de volatilité, 46

pertinence, 46
prévention, 10

Renseignement sur la menace, 92
RFC 3227, 46
réaction, 10
récupérer, 67
réponse, 14

SIEM, 30
SOC, 14
STIX, 92
suffisance, 46
supervision d'exploitation, 10
Supervision de sécurité, 10

TAXII, 92

Verdict à trois valeurs, 108
Vrai positif, 40
vérifiées, 98

© *MaletYon*

À propos de ce cours

Quand un système d'information s'arrête, la question décisive n'est pas technique : elle porte sur qui avait décidé, et qui devait rendre compte. Ce cours apprend à y répondre avant la panne.

Il progresse en six parties, précédées d'un prologue : les fondements de la gouvernance des systèmes d'information, le référentiel COBIT 2019, le cadre normatif et juridique, ITIL 4 et les processus de gestion des services, les défis de l'agilité, du nuage et de l'intelligence artificielle, et enfin la recherche.

Chaque notion est ancrée à la fois dans les standards internationaux (ISO, ISACA, IIA, INTOSAI) et dans le droit camerounais et communautaire (CEMAC, OHADA). Le cours s'adresse aux étudiants du Master Professionnel en Management des Systèmes d'Information et aux professionnels qui exercent comme DSI, responsables GRC, auditeurs des SI, responsables des services informatiques ou RSSI.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information